

Entrega Cybersecurity Sprint 3: ForwardService

FIAP · Challenge Ford 2026 · Desafio 02: VIN Share e retenção no pós-venda

Produto: ForwardService, score de churn e leads proativos de serviço para concessionárias Ford

Disciplina: Cybersecurity · **Professor:** Vitor Miguel Lasse Silva · **Turma:** 3ESPZ

Grupo

Integrante	RM
João Victor Franco	RM556790
Lucca Saraiva Borges	RM554608
Ruan Melo Vieira	RM557599
Rodrigo César Jimenez	RM558148

Data: 27/09/2026 · **Organização GitHub:** github.com/fwd-ford

Documento único da Sprint 3, separado pelas quatro atividades da rubrica e integrado ao projeto Ford (API, mobile, IoT, dados, ML e arquitetura). Ele **continua** a entrega da Sprint 1 e não repete o que já está lá: modelo de ameaças STRIDE em [01_THREAT_MODEL.md](#), OWASP Top 10 2021 em [02_OWASP_TOP10.md](#) e plano de segurança em [03_SECURITY_PLAN.md](#).

Legenda de status usada em todo o documento

Status	Significado
Implementado	Está na branch <code>main</code> (código, configuração ou workflow) e há evidência executada
Em implementação	Código escrito em pull request aberto nesta sprint, ainda não mergeado
Planejado	Decisão tomada e descrita, sem código ainda
Proposto	Desenho de referência (ex.: IoT), sem componente real no projeto

Sumário

- [0. Contexto e escopo](#)
- [1. Pipeline DevSecOps Integrado \(peso 3,0\)](#)
- [2. Segurança em Código e Infraestrutura \(peso 2,5\)](#)
- [3. Observabilidade, Monitoramento e Resposta \(peso 2,0\)](#)
- [4. Compliance, Riscos e Segurança Contínua \(peso 2,5\)](#)
- [Anexos](#)

0. Contexto e escopo

O ForwardService cruza o histórico de serviço dos veículos Ford (VIN pseudonimizado) com um modelo de churn (XGBoost) e entrega às concessionárias leads de retorno à oficina. Os componentes cobertos por esta entrega são:

Componente	Repositório	Tecnologia	Papel na segurança
API REST + SOAP	forward-api-java	Spring Boot 3.5 / Java 17, Fly.io (gru)	Autenticação, RBAC, validação, rate limit, auditoria
App mobile	forward-mobile	Expo SDK 55 / React Native	Sessão do atendente, armazenamento seguro do token
Dados e infraestrutura	forward-infra	Supabase Postgres, migrations, docker compose	RLS, audit_log, retenção LGPD, backup
ML	forward-ml	Python, XGBoost	Score de churn sem PII direta
CI/CD compartilhado	.github	GitHub Actions reutilizáveis	Pipeline DevSecOps da organização
Telemetria IoT	(sem repositório)	MQTT sobre TLS	Proposto: veículos conectados como fonte IoT

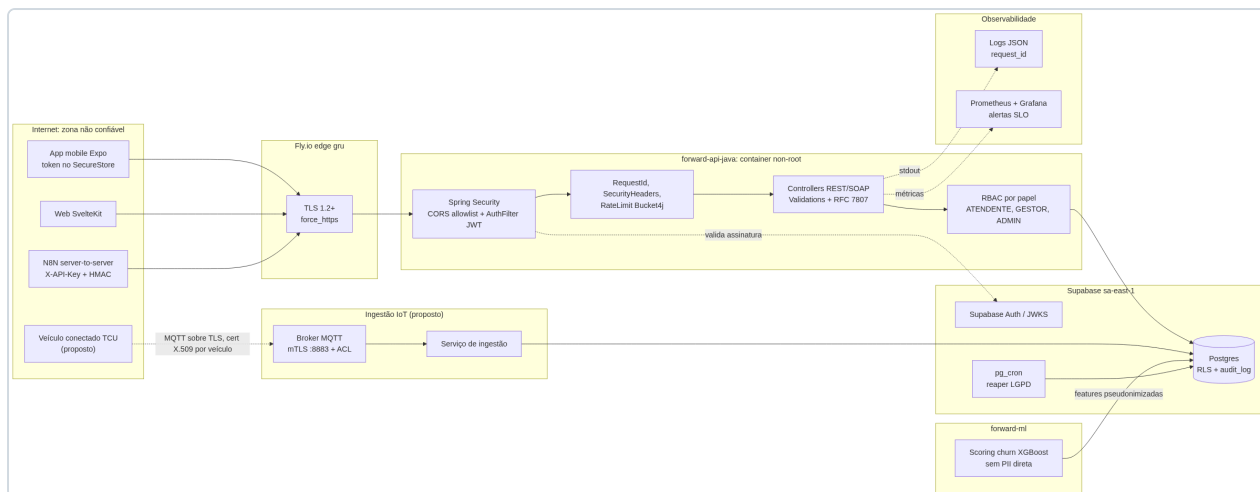


Figura 1. Arquitetura e fronteiras de confiança. Linhas tracejadas da ingestão IoT indicam componentes propostos.

O que mudou desde a Sprint 1: (1) pipeline DevSecOps único e reutilizável rodando em quatro repositórios, com resultados no GitHub code scanning; (2) login próprio da API com JWT e RBAC ATENDENTE / GESTOR / ADMIN (PR aberto) e token do app guardado no SecureStore (mergeado); (3) plano de observabilidade com dashboard, regras de alerta e plano de resposta; (4) revisão final de riscos e checklist de compliance (ASVS, Mobile Top 10, API Top 10, LGPD).

1. Pipeline DevSecOps Integrado (peso 3,0)

1.1 Objetivo

Automatizar, em todo pull request, push na `main`, agenda semanal e execução manual, as verificações de segurança que antes dependiam de revisão humana: SAST, SCA, varredura de segredos, IaC, imagem de container e SBOM, publicando os achados no GitHub code scanning sem travar o fluxo de entrega do time.

1.2 O que foi feito

- **Workflow reutilizável da organização** `.github/workflows/devsecops.yml` (875 linhas): 8 jobs de varredura em paralelo (o CodeQL roda em matriz por linguagem) e 1 job de resumo. Mergeado em `fwd-ford/.github#4` e ajustado em `fwd-ford/.github#10`.
- **Callers em quatro repositórios** (`.github/workflows/devsecops.yml`), mergeados: `forward-api-java#47`, `forward-mobile#97`, `forward-infra#42`, `forward-ml#32`.
- **Autoteste do pipeline** (`devsecops-selftest.yml`): toda mudança no workflow roda o próprio pipeline sobre o repositório `.github` antes de chegar aos callers.
- **Dependabot com cooldown de 7 dias** nos dois repositórios que ainda não tinham: `.github` (`dependabot.yml`) e `forward-web` (`forward-web#3`, só GitHub Actions porque o app ainda não tem `package.json`). Os demais já tinham Dependabot (Maven, npm, pip, Docker, Actions).

1.3 Desenho do pipeline

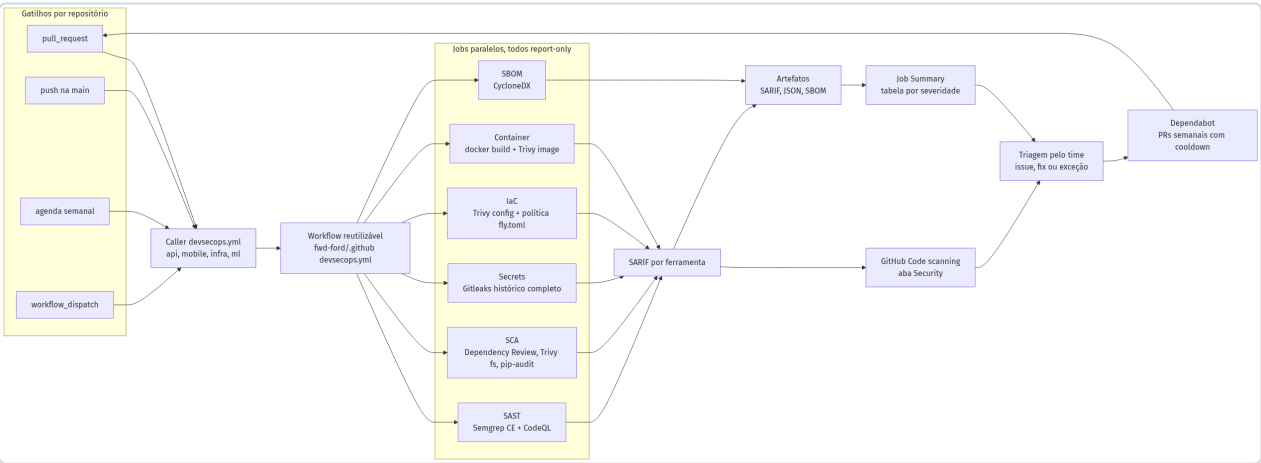


Figura 2. Fluxo do pipeline: gatilhos, jobs paralelos, SARIF, code scanning, resumo e triagem.

Estágio	Ferramenta (versão fixada)	Quando roda	Saída	Como reduz riscos do projeto
SAST	Semgrep CE 1.178.0 (container oficial por digest) com rulesets por repo	Todo evento	SARIF semgrep	Pega injeção, uso inseguro de API, workflows com shell injection (STRIDE T/E; OWASP A03, A05) antes do merge

Estágio	Ferramenta (versão fixada)	Quando roda	Saída	Como reduz riscos do projeto
SAST	CodeQL security-extended , matriz por linguagem (java-kotlin , javascript-typescript , python , actions), build-mode: none	Todo evento	SARIF por linguagem	Análise de fluxo de dados (taint) no código Java/TS/Python e nos próprios workflows (supply chain de CI)
SCA	dependency-review-action v5 (warn-only)	Só em PR	Resumo no job	Barra a introdução de dependência vulnerável no diff do PR (OWASP A06, Mobile M2)
SCA	Trivy 0.74.0 fs --scanners vuln (pom.xml, package-lock.json) + pip-audit 2.9.0 (requirements resolvidos)	Todo evento	SARIF trivy-sca + JSON	Inventário de CVEs em dependências diretas e transitivas; cobre o requirements.txt com ranges >= do ML
Secrets	Gitleaks 8.30.1 no histórico completo do git, relatório redigido	Todo evento	SARIF gitleaks	Detecta chave/token commitado em qualquer commit antigo (STRIDE S/I; ASVS V2.10.4; LGPD art. 46)
laC	Trivy config (Dockerfile e afins) + política própria para fly.toml (FLY001 force_https, FLY002 segredo em [env])	Todo evento	SARIF trivy-iac e fly-policy	Evita container como root, TLS desligado na borda e segredo em manifesto (OWASP A05, API8)
Container	docker build local (imagem nunca publicada) + Trivy image	Repos com Dockerfile (API)	SARIF trivy-image + SBOM da imagem	Vê o que realmente vai para produção: pacotes do SO e JARs dentro do fat jar
SBOM	CycloneDX via Trivy (fonte, imagem e Python resolvido)	Todo evento	Artefato (90 dias)	Resposta rápida a um novo CVE: saber em minutos se a lib está em uso
Resumo	Script do job summary	Sempre	Tabela no Job Summary + devsecops-summary.json	Visão única por severidade para a triagem semanal

1.4 Como o pipeline roda no projeto Ford

Repositório	Componente Ford	CodeQL	Semgrep	SCA	Container	Observações
forward-api-java	API que atende app, web e N8N	java-kotlin , actions	p/default p/owasp-top-ten p/java p/dockerfile	Trivy fs (pom resolvido pelo Maven)	Sim, Dockerfile e de produção	Único repo com imagem; política fly.toml ativa
forward-mobile	App do atendente (Android)	javascript-typescript , actions	p/default p/owasp-top-ten p/typescript p/react	Trivy fs no package-lock.json	Não	Gitleaks respeita o allowlist da anon key pública (presente no histórico)
forward-infra	Banco Supabase, RLS, LGPD	actions	p/default p/docker-compose	Trivy fs	Não	Foco em laC e compose de desenvolvimento

Repositório	Componente Ford	CodeQL	Semgrep	SCA	Container	Observações
forward-ml	Modelo de churn e scoring	python , actions	p/default p/python p/owasp-top-ten	pip-audit sobre o conjunto resolvido	Não	SBOM do Python resolvido (49 pacotes)

Trecho do caller da API (o agendamento `17 6 * * 1` é segunda-feira às 03:17 BRT) ([forward-api-java/.github/workflows/devsecops.yml:8-35](#)):

```
on:
  push:
    branches: [main]
  pull_request:
    branches: [main]
  schedule:
    - cron: "17 6 * * 1"
  workflow_dispatch:

permissions:
  contents: read
  security-events: write
  pull-requests: read

concurrency:
  group: devsecops-${{ github.ref }}
  cancel-in-progress: true

jobs:
  devsecops:
    name: DevSecOps
    uses: fwd-ford/.github/.github/workflows/devsecops.yml@main
    with:
      codeql-languages: '["java-kotlin","actions"]'
      semgrep-config: "p/default p/owasp-top-ten p/java p/dockerfile"
      dockerfile: Dockerfile
      docker-context: "."
      run-container-scan: true
```

Fluxo do time: o desenvolvedor abre o PR, o pipeline roda em cerca de 2 minutos, os achados novos aparecem como anotações de code scanning no próprio PR e a tabela de severidade fica no resumo do run. Na segunda-feira o agendamento varre a `main` inteira (inclusive CVEs publicadas durante a semana) e a triagem semanal decide: corrigir, abrir issue com prazo pelo SLA ([seção 4.8](#)) ou descartar com justificativa registrada no alerta.

1.5 Segurança do próprio pipeline

O pipeline é parte da superfície de ataque (cadeia de suprimentos de CI). Decisões tomadas, visíveis em [devsecops.yml:80-90](#) :

```
permissions:
  contents: read
  security-events: write
  pull-requests: read

env:
  TRIVY_VERSION: "0.74.0"
```

```
TRIVY_SHA256: "2ae6fe3ee734b7fdf11335663e18c75ea12dcc76062f09f164a3b0f8be4371a"
GITLEAKS_VERSION: "8.30.1"
GITLEAKS_SHA256: "551f6fc83ea457d62a0d98237cbad105af8d557003051f41f3e7ca7b3f2470eb"
SEMGREP_IMAGE:
"semgrep/semgrep:1.178.0@sha256:32e459968daabe7ab86968184a29109b9564aa00392401156f9788452b42786b"
```

- **Nada mutável:** actions fixadas por SHA de commit (ex.: `actions/checkout@d23441a... #v6.1.0`), binários por versão + SHA-256 conferido com `sha256sum -c` ([linha 244](#)) e Semgrep por digest. Motivo concreto: em março de 2026 tags da `aquasecurity/trivy-action` foram sequestradas; o workflow antigo `java-security.yml` ainda usa `trivy-action@master`.
- **Menor privilégio:** o token só lê código e escreve em code scanning; `persist-credentials: false` em todos os checkouts; nenhum segredo é necessário.
- **Report-only de propósito:** todo passo de scan e todo job são `continue-on-error`. Um gate bloqueante com 87 achados abertos na API travaria a entrega da sprint; o gate existente (`java-security.yml`) já fica vermelho nos PRs da API por CVEs de terceiros ([exemplo](#)). A política é: tornar bloqueante só **Critical novo** depois que a linha de base for zerada ([seção 1.8](#)).
- **Correção de bug herdado:** `secrets-scan.yml` usa `fetch-depth: ${{ inputs.scan-history && 0 || 1 }}`; como `0` é falsy nas expressions do Actions, o resultado é sempre `1` e o "scan de histórico" nunca buscou o histórico. O novo workflow usa a string `'0'` ([linha 347](#)).
- **Iteração real:** o primeiro run da API falhou no Trivy com HTTP 429 do Maven Central ao resolver o BOM do Spring ([run 36298364077](#)). A correção ([.github#10](#)) resolve as dependências com Maven e cache antes do Trivy, validada no [run 36298745497](#).

1.6 Evidências

Pull requests desta entrega

PR	Repositório	Conteúdo	Estado
#4	.github	Workflow reutilizável, autoteste, Dependabot com cooldown	Mergeado (e96379a)
#10	.github	Maven antes do Trivy, SBOM Python, resumo mais claro	Mergeado (b5cb51a)
#47	forward-api-java	Caller com CodeQL Java e scan da imagem	Mergeado (accdab9)
#97	forward-mobile	Caller com CodeQL JS/TS	Mergeado (e5b3cef)
#42	forward-infra	Caller com foco em IaC	Mergeado (19114d3)
#32	forward-ml	Caller com CodeQL Python e pip-audit	Mergeado (5a7af86)
#3	forward-web	Dependabot (GitHub Actions) com cooldown	Mergeado (a3f5300)

Execuções na `main` (workflow_dispatch em 27/09/2026, todas com sucesso)

Repositório	Run	Commit
forward-api-java	36299068758	accdab9
forward-mobile	36299071189	0db4953
forward-infra	36299073383	19114d3
forward-ml	36299075207	5a7af86
.github (autoteste)	36299076861	b5cb51a

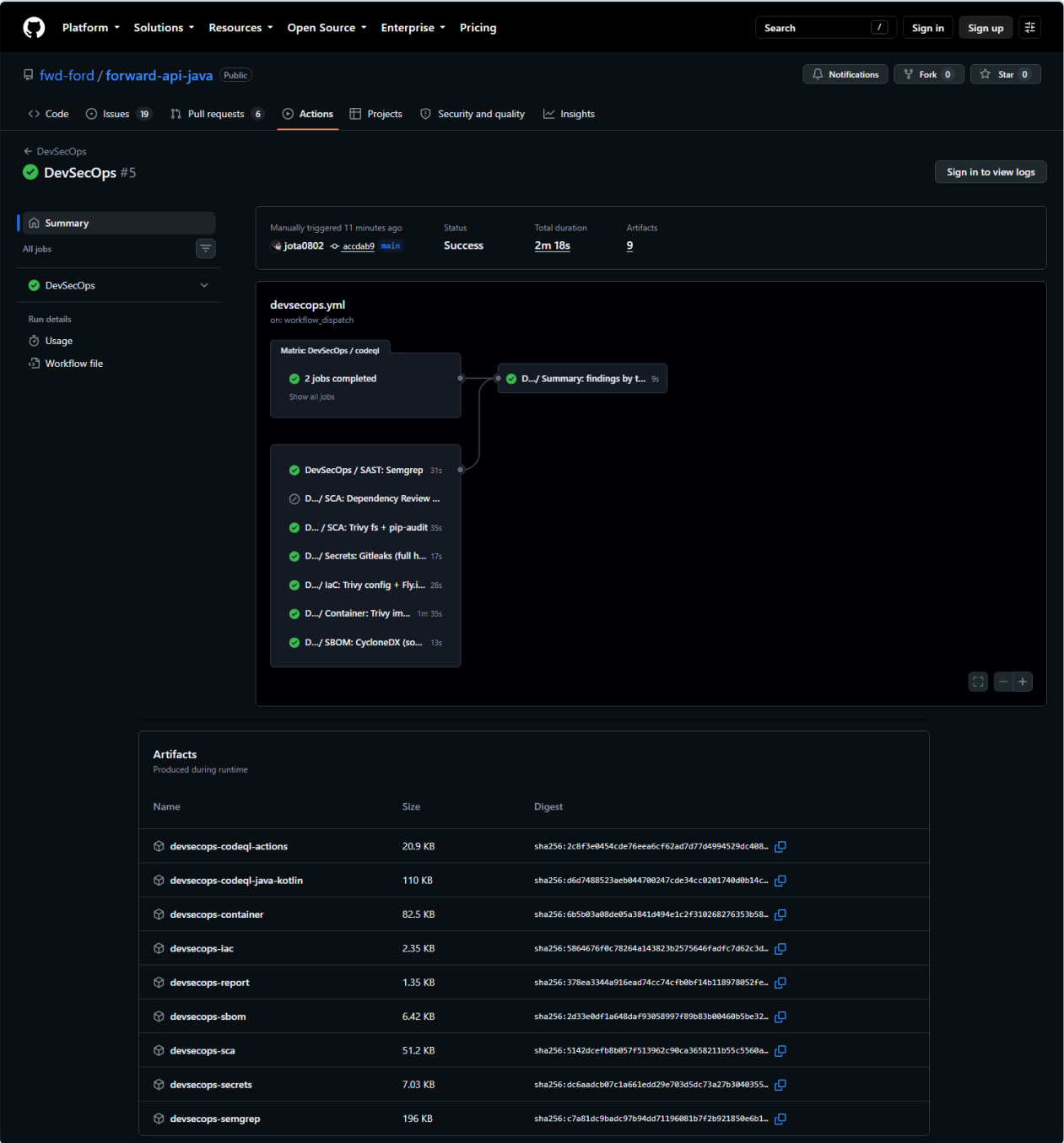


Figura 3. Print real (27/09/2026) da execução 36299068758 na forward-api-java: 9 jobs verdes (o dependency review só roda em PR) e 9 artefatos (SARIF, JSON e SBOM) com digest SHA-256.

Achados por ferramenta e severidade (resumo gerado pelo pipeline; JSON completo em evidencias/devsecops-achados-2026-09-27.json)

Repositório	Semgrep	CodeQL	Trivy fs (deps)	Gitleaks	Trivy config / Fly	Trivy image	Critical	High	Medium	Low	Total
forward-api-java	2	6	39	0	1 / 0	39	6	23	49	9	87
forward-mobile	10	4	49	0	0 / 0	n/a	1	36	25	1	63
forward-infra	2	2	0	0	0 / 0	n/a	0	0	4	0	4

Repositório	Semgrep	CodeQL	Trivy fs (deps)	Gitleaks	Trivy config / Fly	Trivy image	Critical	High	Medium	Low	Total
forward-ml	3	2	0 (pip-audit: 0 em 48 pacotes)	0	0 / 0	n/a	0	0	5	0	5
.github	21	7	0	0	0 / 0	n/a	0	4	24	0	28

Na API, Trivy fs e Trivy image apontam as **mesmas 39 CVEs** das bibliotecas Java (visão do código e visão da imagem); os pacotes Alpine 3.24.2 da imagem têm **zero** vulnerabilidades. SBOMs gerados: API 91 componentes (fonte) e 157 (imagem), mobile 680, ML 49 (Python resolvido).

Triagem dos principais achados

ID	Ferramenta	Achado	Onde	Severidade	Decisão
T-01	Trivy	tomcat-embed-core 10.1.55: CVE-2026-65182, CVE-2026-65905, CVE-2026-68525 (corrigido em 10.1.58)	<code>pom.xml:27</code> fixa a versão	Critical	Planejado: subir <code>tomcat.version</code> para 10.1.58 logo após o merge do PR de JWT/RBAC, para não conflitar
T-02	Trivy	jackson-databind 2.21.2, spring-webmvc 6.2.18, micrometer-core 1.15.11, postgresql 42.7.11, spring-ws 4.1.3 (SSRF e XXE)	BOM do Spring Boot 3.5.14	High	Planejado: atualizar para o último patch da linha 3.5 e revisar o <code>.trivyignore</code> , cuja revisão venceu em 01/08/2026
T-03	Trivy	shell-quote 1.8.3 (CVE-2026-9277), @xmldom/xmldom, js-yaml, brace-expansion, nanoid, postcss, ws	package-lock.json do mobile	Critical / High	Quase tudo é toolchain de build (Metro, Expo CLI), não vai no APK. Planejado: mergear os PRs do Dependabot abertos desde maio (#62 a #66)
T-04	CodeQL	java/spring-disabled-csrf-protection	<code>SecurityConfig.java:28</code>	High (8,8)	Falso positivo aceito: API stateless com Bearer token, sem cookie de sessão. Planejado: dispensar o alerta no code scanning com esta justificativa
T-05	CodeQL	java/log-injection (URI e mensagem de exceção no log)	<code>GlobalExceptionHandler.java:66</code>	Medium	Parcial: o encoder JSON de produção escapa CR/LF; Planejado: sanitizar no console de dev
T-06	Semgrep + CodeQL	Shell injection por <code>\${{ inputs.* }}</code> em run: e actions por tag mutável (inclui trivy-action@master)	java-quality.yml:24/36/48, secrets-scan.yml:29, java-security.yml:15	High / Medium	Real. Os arquivos antigos ficaram intocados nesta entrega (restrição do time); Planejado: mesmo padrão do devsecops.yml (env + SHA)
T-07	CodeQL	actions/unpinned-tag nos callers @main e em android-apk.yml	Callers e workflow do APK	Medium	Callers em @main é intencional (repo interno com PR obrigatório); android-apk.yml Planejado: fixar por SHA

ID	Ferramenta	Achado	Onde	Severidade	Decisão
T-08	Semgrep	dependabot-missing-cooldown	dependabot.yml dos repos de app	Medium	Corrigido no <code>.github</code> (cooldown 7 dias); demais Planejado
T-09	Semgrep	insecure-hash-algorithm-sha1	<code>scripts/internal_analysis.py:374</code>	Medium	Aceito: script de pesquisa que testa a reversão do VIN_Hash SHA-1 fornecido pela Ford; não é controle de segurança
T-10	Trivy config	DS-0026 sem HEALTHCHECK (26 checagens OK, 1 falha)	Dockerfile	Low	Mitigado pelo health check do Fly.io (<code>fly.toml:24-29</code>)
T-11	Gitleaks	Histórico completo dos quatro repositórios	todos	0	Nenhum segredo encontrado

1.7 Resumo de como o pipeline reduz os riscos identificados

Risco (Sprint 1 ou revisão Sprint 3)	Estágio que detecta	Efeito
Dependência com CVE (A06, M2, API8)	SCA, Container, Dependency Review	Descoberta semanal automática; na primeira varredura revelou 3 CVEs críticas no Tomcat 10.1.55 fixado no <code>pom.xml</code> e a revisão vencida do <code>.trivyignore</code>
Segredo commitado (INTERNAL_API_KEY, JWT secret)	Secrets (histórico completo)	Garantia de que nenhum segredo está no histórico, não só no último commit
Injeção e uso inseguro de API (A03)	SAST Semgrep + CodeQL	Achado aparece no PR, antes do merge
Configuração insegura de container e borda (A05)	laC + política <code>fly.toml</code>	Container root ou <code>force_https=false</code> viram alerta Critical/High
Supply chain do CI (actions comprometidas)	CodeQL <code>actions</code> , Semgrep <code>github-actions</code> , pins por SHA	Achados reais nos workflows antigos; o novo pipeline não depende de ref mutável
Resposta lenta a CVE nova	SBOM CycloneDX	Consulta imediata de "onde usamos a lib X"

1.8 Limitações e próximos passos

- **Dependency graph desabilitado:** o `dependency-review-action` termina com "Dependency review is not supported on this repository". Habilitar em *Settings > Advanced Security > Dependency graph* é ação do owner da organização (**Planejado**); enquanto isso o Trivy cobre o SCA.
- **Secret scanning e push protection do GitHub** estão desligados nos repositórios públicos, embora sejam gratuitos. **Planejado:** ligar (bloqueia o push do segredo, o Gitleaks só detecta depois).
- **Gate bloqueante: Planejado** para depois de zerar a linha de base: falhar o PR só com achado Critical **novo** (diff), mantendo o resto report-only.
- **DAST:** OWASP ZAP baseline contra um ambiente de staging, mensal (**Planejado**).
- **Proveniência:** assinatura da imagem com cosign e atestado SLSA (**Planejado**).

2. Segurança em Código e Infraestrutura (peso 2,5)

2.1 Objetivo

Mostrar correções e controles reais no código e na infraestrutura: criptografia local, hardening da API (rate limit, validação, JWT seguro), controle de acesso por papel, segurança da telemetria IoT e segurança de IaC, com trechos de código, links para commits e evidência executada.

2.2 Mapa de controles

Controle	Onde	Status	Evidência
Token do app no Keystore/Keychain	<code>forward-mobile/lib/session.ts</code>	Implementado (#98)	session.ts:37-53
APK release só HTTPS	<code>forward-mobile/app.config.js</code>	Implementado	app.config.js:9-16
Rate limit Bucket4j (429 + Retry-After)	<code>RateLimitFilter</code>	Implementado; cobertura de requisições não autenticadas em implementação	RateLimitFilter.java:37-60
Validação de entrada (allowlist)	<code>Validations , Bean Validation</code>	Implementado	Validations.java:11-78
Headers de segurança	<code>SecurityHeadersFilter</code>	Implementado (falta no 401, ver F-01)	SecurityHeadersFilter.java:23-28
JWT com iss, aud, exp, jti e segredo mínimo de 256 bits	<code>JwtService</code>	Em implementação (#48)	JwtService.java:76-102
RBAC ATENDENTE / GESTOR / ADMIN	<code>Role , @PreAuthorize , RLS</code>	Em implementação (#48); RLS legado implementado	Role.java:12-44
HMAC-SHA256 server-to-server	<code>HmacValidator</code>	Implementado	HmacValidator.java:58-79
RLS no Postgres	<code>migration 010</code>	Implementado para acesso direto via Supabase; não filtra a API (F-17)	010_rls_policies.sql:5-53
Retenção e anonimização LGPD	<code>migration 013 + pg_cron</code>	Implementado	013_lgpd_retention_policy.sql:21-101
Container non-root	<code>Dockerfile</code>	Implementado	Dockerfile:9-14
MQTT sobre TLS com mTLS e ACL	<code>iot/ desta entrega</code>	Proposto	mosquitto.conf, acl

2.3 Criptografia local e proteção de dados

Mobile: token no armazenamento seguro do sistema. O login do app passou a usar o JWT emitido pela própria API ([forward-mobile#98](#), mergeado em 27/09/2026). A sessão é gravada com `expo-secure-store`, que cifra o valor com chave do Android Keystore (AES-GCM) ou guarda no iOS Keychain ([lib/session.ts:37-53](#)):

```

async function readRaw(): Promise<string | null> {
  if (Platform.OS === "web") {
    return typeof window === "undefined" ? null : window.localStorage.getItem(STORE_KEY);
  }
  return SecureStore.getItemAsync(STORE_KEY);
}

async function writeRaw(value: string | null): Promise<void> {
  if (Platform.OS === "web") {
    if (typeof window === "undefined") return;
    if (value === null) window.localStorage.removeItem(STORE_KEY);
    else window.localStorage.setItem(STORE_KEY, value);
    return;
  }
  if (value === null) await SecureStore.deleteItemAsync(STORE_KEY);
  else await SecureStore.setItemAsync(STORE_KEY, value);
}

```

- **Ciclo de vida do token:** expiração local com 30 s de margem ([lib/auth.ts:12-21](#)), descarte da sessão vencida ao abrir o app ([session.ts:60-73](#)) e logout automático em qualquer 401 ([lib/api.ts:79-83](#)).
- **Separação do que é sensível:** AsyncStorage (sem cifra) guarda só preferências (tema, idioma, cidade) e o avatar, que fica só no aparelho ([lib/profile.ts:1-4](#)).
- **Em trânsito:** o APK de release bloqueia HTTP em texto claro (`usesCleartextTraffic: false` , só liberado com `ALLOW_HTTP=1` em build local) ([app.config.js:9-16](#)); a API força HTTPS na borda ([fly.toml:16-18](#)) e envia HSTS de 1 ano.
- **Banco:** Supabase cifra o armazenamento em repouso (AES-256, controle do provedor); `cpf_hash` é SHA-256 gerado pelo banco ([002_create_customers.sql:9](#)). **Achado F-09:** a coluna `cpf` continua em claro (linha 8), ao contrário do que o `SECURITY.md` do infra afirma. **Planejado:** cifrar com `pgcrypto` (chave no Vault do Supabase) ou manter só um HMAC com pepper.
- **Limitação aceita:** no build **web** de demonstração o token fica em `localStorage` (sem Keystore no navegador). O canal oficial do atendente é o APK.

2.4 Hardening da API

Controle	Implementação (main)	Referência
Rate limit	Bucket4j, 60 req/min por IP + <code>sub</code> , resposta 429 RFC 7807 com <code>Retry-After</code>	RateLimitFilter.java:37-78
Limite de corpo	Tomcat <code>max-http-form-post-size</code> e <code>max-swallow-size</code> 1 MB	application.yml:6-8
Validação de entrada	Regex RFC 4122 (UUID), ISO 3779 (VIN), enum allowlist, <code>limit</code> em [1, 200]	Validations.java:11-78
Bean Validation	<code>serviceCode</code> 1..5, <code>mainSource</code> por regex, campos obrigatórios	CreateServiceEventRequest.java:17-69
Erros sem vazamento	RFC 7807 genérico, stack trace só no log	GlobalExceptionHandler.java:63-73
Headers e CORS	HSTS, CSP <code>default-src 'none'</code> , nosniff, DENY; CORS por allowlist	SecurityHeadersFilter.java:23-46 , CorsConfig.java:24-35
Actuator restrito	Só <code>health</code> e <code>info</code> , <code>show-details: never</code>	application.yml:26-34

Controle	Implementação (main)	Referência
Integridade server-to-server	HMAC-SHA256 de <code>ts:METHOD:path:sha256(body)</code> , janela de 5 min, comparação em tempo constante	HmacValidator.java:58-124

Evidência em produção (27/09/2026, 03:13 BRT). Requisições reais contra `https://forward-api-java.fly.dev` (saída resumida: headers de cache e `vary` omitidos):

```
$ curl -sD - https://forward-api-java.fly.dev/health
HTTP/1.1 200
x-request-id: d361eed3-9a24-4c11-be88-5fb6bb826d87
x-content-type-options: nosniff
x-frame-options: DENY
referrer-policy: no-referrer
strict-transport-security: max-age=31536000; includeSubDomains
content-security-policy: default-src 'none'; frame-ancestors 'none'
permissions-policy: geolocation=(), microphone=(), camera=()
server: Fly/67a399e710 (2026-09-23)

$ curl -sD - https://forward-api-java.fly.dev/api/v1/leads (sem token)
HTTP/1.1 401
x-content-type-options: nosniff
x-frame-options: DENY
content-type: application/problem+json; charset=ISO-8859-1
{"status":401,"detail":"Token ausente ou invalido.","code":"unauthorized","title":"Nao autenticado","type":"about:blank"}

70 requisições seguidas sem token em /api/v1/leads -> 70 x 401, nenhum 429
70 requisições seguidas em /health -> 69 x 200, 1 x 429
```

O teste confirma o rate limit e os headers em rotas que passam por todos os filtros, e revela o **achado F-01**: na `main`, a cadeia do Spring Security (ordem -100) roda **antes** de `RequestIdFilter (@Order(0))`, `SecurityHeadersFilter (@Order(1))` e `RateLimitFilter (@Order(10))` ([RateLimitFilter.java:25-27](#)). Quando o `AuthFilter` responde 401 ele encerra a cadeia, então a resposta sai sem HSTS/CSP, sem `x-Request-Id` e **sem rate limit**: um atacante pode testar tokens em volume. O PR #48 (em implementação) reordena os filtros para `RequestIdFilter -> SecurityHeadersFilter -> RateLimitFilter -> Spring Security` ([SecurityConfig.java:3-8 no PR](#)) e adiciona um balde exclusivo para `POST /api/v1/auth/login` ([RateLimitFilter.java:35-84 no PR](#)).

JWT seguro.

- **Hoje na main (tokens do Supabase):** assinatura verificada com `jjwt (verifyWith`, que também valida `exp`) ([Hs256JwtValidator.java:20-22](#)); no caminho JWKS só RS256 e ES256 são aceitos, o que bloqueia `alg: none` e confusão de algoritmo ([JwksJwtValidator.java:23-25](#)). Lacunas: `issuer` configurado mas não validado (F-04) e modo aberto quando nenhum validador está configurado (F-02, [AuthFilter.java:68-73](#)).
- **Em implementação no PR #48:** a API vira seu próprio provedor de identidade. JWT HS256 com `iss=forward-api`, `aud=forward-app`, `exp`, `nbf`, `jti` aleatório e tolerância de relógio de 30 s ([JwtService.java:76-78](#)); segredo de no mínimo 256 bits e **falha na inicialização** se faltar em produção ([JwtService.java:88-102](#)); senha com BCrypt e resposta igual para e-mail inexistente e senha errada, inclusive no tempo (hash fictício), contra enumeração de contas ([AuthService.java:43-59](#)); `X-API-Key` comparada em tempo constante sobre digests SHA-256 ([JwtAuthenticationFilter.java:89](#)); política de senha de 8 a 72 caracteres com classes mistas; cada tentativa de login gravada no `audit_log`.

2.5 Controle de acesso baseado em papéis (RBAC)

A rubrica usa os papéis genéricos Brigadista, Gestor e Administrador. No ForwardService eles correspondem a:

Papel da rubrica	Papel no projeto	Quem é	Escopo
Brigadista (linha de frente)	ATENDENTE	Atendente de pós-venda da concessionária que liga para o cliente e trata o lead	Só a própria concessionária
Gestor	GESTOR	Gerente de serviços da concessionária	Só a própria concessionária, com escrita de eventos de serviço
Administrador	ADMIN	Administrador da plataforma (equipe ForwardService / Ford)	Todas as concessionárias, gestão de usuários
(sem equivalente)	SERVICE	Integração server-to-server (N8N, jobs) via X-API-Key	Nunca atribuído a pessoa, nunca vai em JWT

Matriz de permissões (definida em [Role.java:12-44](#) do [PR #48](#), em implementação):

Permissão	ATENDENTE	GESTOR	ADMIN	SERVICE
leads:read , leads:update	Sim	Sim	Sim	Sim
customers:read , vehicles:read , scores:read	Sim	Sim	Sim	Sim
service-events:read	Sim	Sim	Sim	Sim
service-events:write	Não	Sim	Sim	Sim
service-events:delete	Não	Não	Sim	Não
users:manage	Não	Não	Sim	Não
dealers:all (ver todas as concessionárias)	Não	Não	Sim	Sim

Defesa em profundidade:

1. **Borda da API:** `anyRequest().authenticated()` com rotas públicas explícitas ([SecurityConfig.java:100-101](#) no [PR](#)).
2. **Serviço:** `@PreAuthorize` por papel e filtro programático por `dealer_id` para ATENDENTE e GESTOR (o JWT só é emitido com `dealer_id` para papéis com escopo, [JwtService.java:187](#) no [PR](#)).
3. **Banco:** RLS habilitado em todas as tabelas com PII, com negação por padrão e `audit_log` legível só por admin ([010_rls_policies.sql:5-53](#)). Ressalva da revisão (F-17): o RLS protege o acesso direto pelo Supabase (chaves anon/authenticated), mas **não filtra a API**, que conecta como dono das tabelas; hoje a barreira efetiva é a camada de serviço.
4. **Cliente:** o app só adapta a interface ao papel ([session.ts:12](#)); a decisão é sempre do servidor.

Estado na main e transição. As policies RLS e o `ScoreService` ainda usam os papéis legados do Supabase (`user` , `dealer` , `analyst` , `admin`) ([ScoreService.java:19-24](#)), e o `CustomerService` foi relaxado na Sprint 1 para qualquer usuário autenticado ([CustomerService.java:24-29](#)), um risco de BOLA (API1) registrado como R-03 no infra. Mapeamento usado na migração: `dealer` vira ATENDENTE ou GESTOR conforme o cargo, `analyst` e `admin` viram ADMIN, `user` (cliente final) não tem acesso ao app do atendente. **Planejado:** migration nova reescrevendo as policies do Supabase para os papéis novos.

2.6 Segurança IoT: telemetria de veículos conectados (Proposto)

Status: PROPOSTO, não implementado. O projeto não tem dispositivo físico. Tratamos como fonte IoT a telemetria dos veículos Ford conectados (cerca de 20% da frota; os outros 80% usam o "Fluxo Simplificado" por ordens de serviço). A telemetria (odômetro, códigos DTC, bateria, vida útil do óleo e localização aproximada) melhoraria a previsão de revisão e o score de churn.

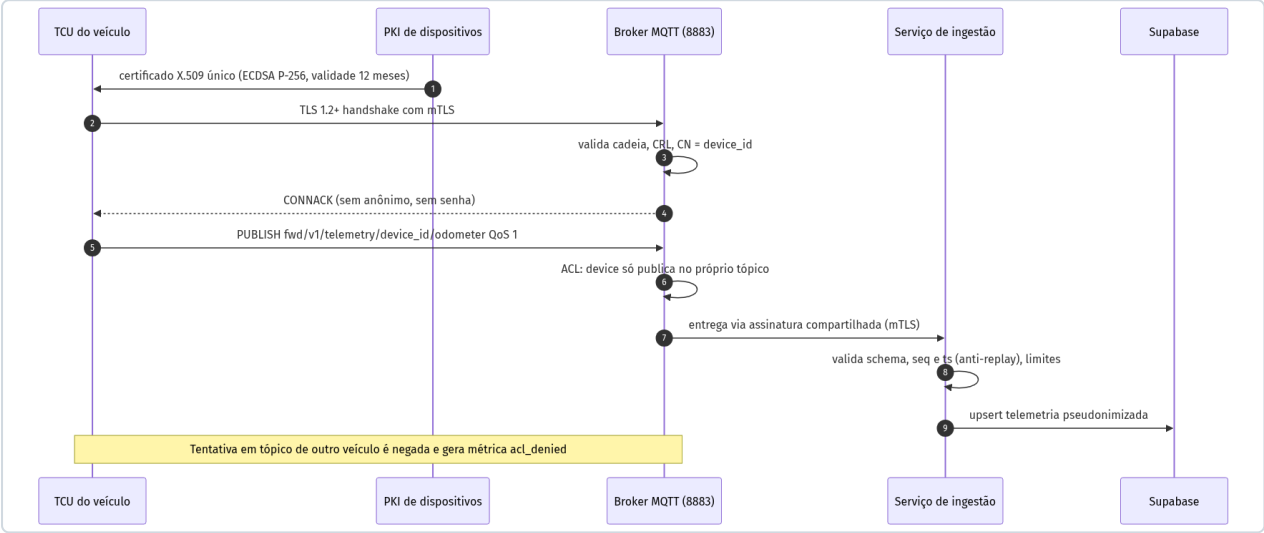


Figura 4. Sequência proposta: certificado por veículo, handshake mTLS, ACL por tópico e validação anti-replay na ingestão.

Desenho de referência

Controle	Decisão	Ameaça tratada (STRIDE)
Transporte	MQTT só na porta 8883 com TLS 1.2 mínimo (1.3 quando disponível), sem porta 1883	Interceptação e adulteração (I, T)
Autenticação do dispositivo	mTLS com certificado X.509 único por veículo (ECDSA P-256, validade de 12 meses, rotação por OTA), CRL publicada	Dispositivo falso ou clonado (S)
Identidade	CN do certificado = <code>device_id</code> pseudônimo (nunca o VIN), usado como usuário MQTT; sem cliente anônimo e sem senha	Vazamento de identificador (I)
Autorização	ACL por tópico: cada veículo só publica em <code>fwd/v1/telemetry/<device_id>/+</code> e só lê a própria configuração; sem comandos remotos ao veículo	Escalada e movimento lateral (E)
Integridade da mensagem	Schema JSON estrito, <code>seq</code> monotônico e <code>ts</code> com janela, rejeição de replay	Replay e injeção (T, R)
Disponibilidade	<code>max_packet_size</code> 16 KB, fila e inflight limitados, alerta de falha de autenticação	Flood de mensagens (D)
Privacidade	Localização com 2 casas decimais (cerca de 1 km), sem nome/contato no payload, broker não loga payload	LGPD: minimização (art. 6, III)
Operação	Em produção, preferir serviço gerenciado com os mesmos controles (AWS IoT Core ou Azure IoT Hub, ambos com X.509 por dispositivo)	Custo de operar PKI e broker

Trecho do `iot/mosquitto.conf` (Mosquitto 2.x) e da `iot/acl` :

```

listener 8883
cafile /mosquitto/certs/fwd-device-ca-chain.pem
certfile /mosquitto/certs/broker.fwd-telemetry.crt
keyfile /mosquitto/certs/broker.fwd-telemetry.key
crlfile /mosquitto/certs/fwd-device-ca.crl
tls_version tlsv1.2
require_certificate true
use_identity_as_username true
allow_anonymous false
acl_file /mosquitto/config/acl
max_packet_size 16384

# acl
pattern write fwd/v1/telemetry/%u/+
pattern read fwd/v1/config/%u
user svc-telemetry-ingest
topic read $share/ingest/fwd/v1/telemetry/#

```

O contrato do payload está em [iot/telemetry.schema.json](#) (JSON Schema 2020-12, `additionalProperties: false`). Métricas e alertas do broker estão na [seção 3.4](#).

2.7 Segurança de infraestrutura como código

- **Dockerfile da API** ([Dockerfile:1-14](#)): build multi-stage (JDK só no estágio de build), runtime `eclipse-temurin:17-jre-alpine`, usuário sem privilégio `app` (uid 10001) e nenhum segredo na imagem. O Trivy config passou em 26 de 27 checagens (única falha: DS-0026 `HEALTHCHECK`, coberto pelo health check do Fly.io) e o scan da imagem confirmou `User=app` e zero CVEs nos pacotes Alpine. **Planejado**: fixar a imagem base por digest e adicionar `HEALTHCHECK`.
- **fly.toml** ([fly.toml:7-29](#)): `force_https = true`, `[env]` sem segredos (segredos só via `fly secrets set`) e health check em `/health`. A política FLY001/FLY002 do pipeline verifica isso a cada PR (0 achados).
- **docker compose de desenvolvimento** ([docker-compose.yml:5-10](#)): credenciais fixas `forward_dev` aceitáveis só em máquina local, mas a porta 55432 é publicada em todas as interfaces (achado F-15). **Planejado**: `127.0.0.1:55432:5432` e `no-new-privileges`.
- **Migrations como IaC**: RLS (010), `audit_log` append-only com `REVOKE UPDATE, DELETE` ([009_create_audit_log.sql:26](#)), reaper LGPD (013) e agendamento `pg_cron` ([lgpd-retention-cron.sql](#)) versionados e revisados por PR.
- **Workflows como IaC**: o pipeline novo segue permissões mínimas e pins por SHA; os achados nos workflows antigos estão em T-06 e T-07.

2.8 Commits e pull requests de evidência

PR	Repositório	Conteúdo de segurança	Estado
#98	forward-mobile	Login JWT na API, sessão no SecureStore, HTTPS-only no APK, permissões mínimas	Mergeado (<code>0db4953</code>)
#48	forward-api-java	JWT próprio, RBAC por perfil e concessionária, RFC 7807 em 401/403, ordem de filtros, IP confiável, rate limit de login	Em implementação (aberto)
#4 , #10	.github	Pipeline DevSecOps	Mergeados
#26	forward-api-java	HmacValidator (Sprint 1)	Mergeado

PR	Repositório	Conteúdo de segurança	Estado
#7	forward-infra	Retenção LGPD, cron e runbook de backup (Sprint 1)	Mergeado
#6	forward-infra	STRIDE do infra (Sprint 1)	Mergeado

2.9 Achados da revisão de código e plano de correção

Revisão manual feita nesta sprint sobre a `main` (API `accdab9`, mobile `0db4953`, infra `19114d3`, ML `5a7af86`), complementar aos scanners.

ID	Achado	Local	Risco	Status
F-01	401 sai sem headers de segurança, sem <code>X-Request-Id</code> e sem rate limit (ordem dos filtros)	<code>RateLimitFilter.java:25-27</code> , <code>RequestIdFilter.java:17-19</code>	Alto (força bruta de token, rastreabilidade)	Em implementação (#48)
F-02	API aberta se nenhum validador JWT estiver configurado (fail-open)	<code>AuthFilter.java:68-73</code> , <code>JwtValidatorFactory.java:42-45</code>	Alto se mal configurado	Em implementação (#48 falha na inicialização)
F-03	<code>X-API-Key</code> comparada com <code>equals</code> (tempo variável)	<code>AuthFilter.java:75-82</code>	Baixo	Em implementação (#48)
F-04	<code>issuer</code> do JWT configurado mas não validado	<code>AppProperties.java:23</code>	Médio	Em implementação (#48 valida iss e aud)
F-05	Chave do rate limit usa <code>getRemoteAddr()</code> , que atrás do proxy do Fly tende a ser o IP do proxy; mapa de baldes sem limite de memória	<code>RateLimitFilter.java:30, 71-78</code>	Médio (DoS)	Em implementação (#48: <code>ClientIpResolver</code> e teto de 50 mil clientes)
F-06	Leitura de qualquer cliente por qualquer usuário autenticado (BOLA)	<code>CustomerService.java:24-29</code>	Alto (PII)	Em implementação (#48: escopo por concessionária)
F-07	VIN completo nos logs de evento de serviço	<code>ServiceEventService.java:53, 76</code>	Médio (LGPD)	Planejado: mascarar para os 6 últimos caracteres
F-08	Log JSON depende do perfil Spring <code>production</code> , mas o Fly define <code>ENV=production</code>	<code>logback-spring.xml:19-29</code> , <code>fly.toml:9</code>	Médio (observabilidade)	Planejado: <code>SPRING_PROFILES_ACTIVE=production</code> no Fly
F-09	CPF em texto claro na tabela <code>customers</code>	<code>002_create_customers.sql:8</code>	Alto (LGPD)	Planejado: <code>pgcrypto</code> ou só HMAC
F-10	CVEs Critical/High em Tomcat, Jackson, Spring, pgjdbc e no toolchain npm	T-01 a T-03	Alto	Planejado (SLA de 7 dias para Critical)
F-11	Workflows antigos com shell injection e actions mutáveis	T-06	Alto (supply chain)	Planejado
F-12	<code>secrets-scan.yml</code> nunca fez scan de histórico (bug do <code>fetch-depth</code>)	<code>secrets-scan.yml:18</code>	Médio	Mitigado pelo novo pipeline (histórico completo)

ID	Achado	Local	Risco	Status
F-13	Modelo carregado com <code>joblib</code> (pickle) e sem lockfile Python (<code>*.lock</code> ignorado no git)	inference.py:64 , .gitignore:38	Médio (execução de código se o artefato for trocado)	Planejado: hash SHA-256 do artefato e <code>requirements</code> com hashes
F-14	Senha mínima de 6 caracteres no app contra 8 no servidor; APK sem R8 e sem chave de assinatura própria documentada	validation.ts:7 , android-apk.yml	Baixo / Médio	Planejado
F-15	Postgres de desenvolvimento publicado em todas as interfaces com senha padrão	docker-compose.yml:9-10	Baixo	Planejado
F-16	SOAP sem validação de payload por XSD (só o VIN é validado no endpoint)	WebServiceConfig.java:22-46	Baixo	Planejado: <code>PayloadValidatingInterceptor</code>
F-17	RLS não filtra as consultas da API: a API conecta como <code>postgres.<ref></code> (dono das tabelas, isento de RLS sem <code>FORCE ROW LEVEL SECURITY</code>) e não define <code>request.jwt.claims</code> , que as <code>policies</code> usam	.env.example:10-11 , 010_rls_policies.sql:17-26	Médio (a defesa em profundidade da Sprint 1 não vale para a API)	Planejado: papel <code>forward_api</code> sem <code>BYPASSRLS</code> , <code>FORCE ROW LEVEL SECURITY</code> e <code>claims</code> por transação

2.10 Limitações e próximos passos

- Os controles marcados "Em implementação" dependem do merge do PR #48; a evidência de produção da seção 2.4 precisa ser repetida depois do deploy.
- IoT é desenho: não há broker, PKI nem dispositivo; o próximo passo seria um laboratório local com Mosquitto e certificados de teste.
- Cifra de campo (CPF, e-mail, telefone) e rotação de chaves continuam planejadas desde a Sprint 1 (R2 do [03_SECURITY_PLAN.md](#)).

3. Observabilidade, Monitoramento e Resposta (peso 2,0)

3.1 Objetivo

Ter sinais suficientes para detectar ataque, falha e degradação em API, mobile, IoT e ML, medir os requisitos de qualidade REQ-01 (p95 da API abaixo de 300 ms) e REQ-02 (disponibilidade de pelo menos 99%) e responder a incidentes com um processo definido, incluindo a comunicação exigida pela LGPD.

3.2 Arquitetura de observabilidade

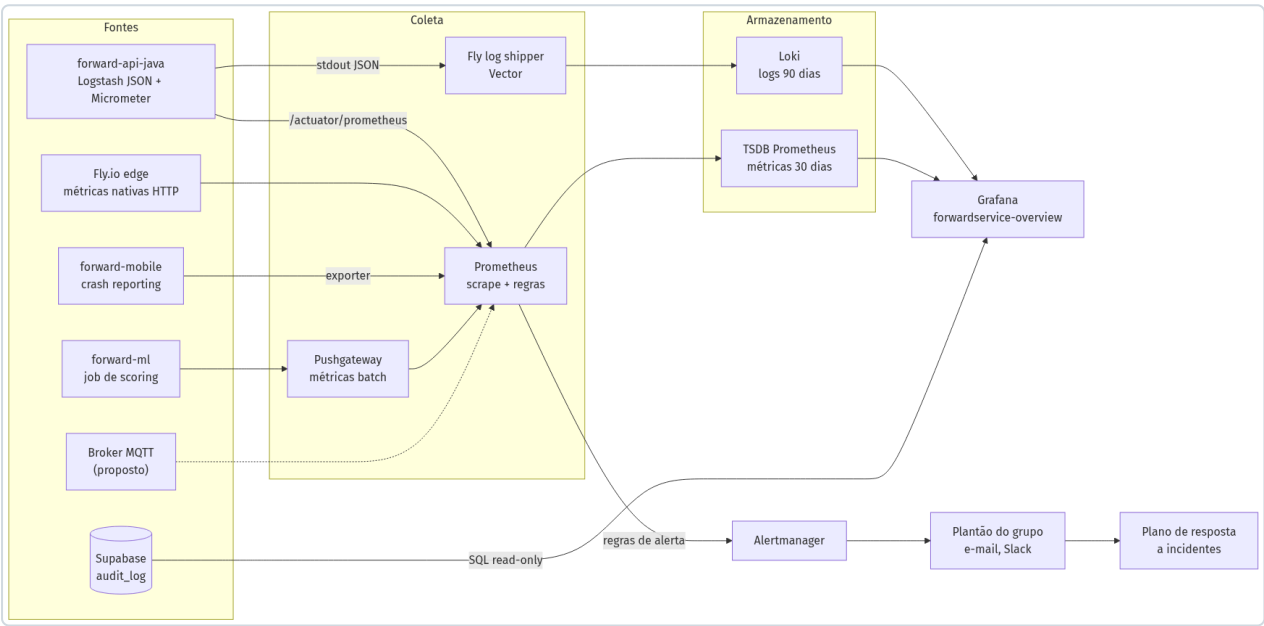


Figura 5. Fontes, coleta, armazenamento, dashboards e alertas. Continua a Monitoring View do TOGAF (06_monitoring_view.png).

Fonte	Sinal	Coleta	Estado
forward-api-java	Logs JSON (LogstashEncoder) com request_id	stdout do Fly, envio para Loki via log shipper	Formato implementado; envio para Loki planejado
forward-api-java	Métricas HTTP (Micrometer http.server.requests)	/actuator/prometheus protegido	Planejado (dependência micrometer-registry-prometheus)
Fly.io edge	Latência e status HTTP na borda	Prometheus gerenciado do Fly	Disponível sem mudança de código
Sonda sintética	probe_success em /health a cada 30 s	blackbox exporter	Planejado
Supabase	audit_log (login, anonimização, mudanças críticas)	Datasource Postgres somente leitura no Grafana	Tabela implementada
forward-mobile	Sessões sem crash, erros de API no app	Crash reporting exportado para Prometheus	Planejado
forward-ml	PSI, AUC, horário do último scoring	Pushgateway ao fim do job	Planejado

Fonte	Sinal	Coleta	Estado
Broker MQTT	Conexões, falhas mTLS, ACL negada, atraso de ingestão	Exporter do broker	Proposto
DevSecOps	Achados abertos por severidade e idade	Exporter da API de code scanning	Planejado (dados reais já existem no pipeline)

3.3 Logs estruturados

Formato atual (implementado). Em produção o `logback-spring.xml` usa `LogstashEncoder` com o campo fixo `service` (`logback-spring.xml:7-11`) e o `RequestIdFilter` coloca o `request_id` no MDC e no header `X-Request-Id` (`RequestIdFilter.java:27-37`). Exemplos no formato exato produzido hoje (`observability/logs/api-logs-formato-atual.jsonl`):

```
{ "@timestamp": "2026-09-27T12:15:07.118Z", "@version": "1", "message": "service_event_rejected\nreason=vin_not_found\nvin=9BFZZZ54ZNB654321", "logger_name": "com.fwdford.forwardapi.service.ServiceEventService", "thread_name": "http-nio-8080-exec-7", "level": "WARN", "level_value": 30000, "request_id": "a81c4d2e-0f6b-4e39-9d17-2b8e5f3c7a90", "service": "forward-api" }\n{ "@timestamp": "2026-09-27T12:40:10.552Z", "@version": "1", "message": "jwt validator: DISABLED (no SUPABASE_JWT_SECRET or SUPABASE_JWKS_URL). Endpoints are open.", "logger_name": "com.fwdford.forwardapi.security.JwtValidatorFactory", "thread_name": "main", "level": "WARN", "level_value": 30000, "service": "forward-api" }
```

O segundo evento é o sinal do fail-open (F-02): ele vira alerta crítico imediato no plano.

Eventos de segurança (formato alvo). O PR #48 já grava `auth.login_failed` e `auth.login_succeeded` no `audit_log` e em log texto. A proposta é emitir os mesmos eventos com campos JSON (StructuredArguments) para alimentar dashboards e alertas (`observability/logs/api-logs-eventos-seguranca.jsonl`):

```
{ "@timestamp": "2026-09-27T13:05:47.903Z", "@version": "1", "message": "login_failed\nreason=invalid_credentials", "logger_name": "com.fwdford.forwardapi.service.AuthService", "thread_name": "http-nio-8080-exec-6", "level": "WARN", "level_value": 30000, "request_id": "5a1f9e3c-7b2d-4c68-8e05-d4b3a2c1f9e7", "service": "forward-api", "event": "auth.login_failed", "outcome": "failure", "reason": "invalid_credentials", "username_hash": "sha256:4b6f1e0a9c2d", "src_ip": "45.155.205.12", "user_agent": "python-requests/2.32.3", "failures_last_5m": 17 }\n{ "@timestamp": "2026-09-27T13:12:40.019Z", "@version": "1", "message": "authz_denied", "logger_name": "com.fwdford.forwardapi.security.ProblemAccessDeniedHandler", "thread_name": "http-nio-8080-exec-2", "level": "WARN", "level_value": 30000, "request_id": "19d4e7b2-8c3a-4f56-a9e1-0b2c5d8f7e36", "service": "forward-api", "event": "authz.denied", "outcome": "failure", "user_id": "8f14e45f-ceea-467a-9c1e-2b7d3a5c6e90", "role": "ATENDENTE", "required_role": "GESTOR", "method": "PATCH", "path": "/api/v1/leads/7e2d9c14-5b8a-4f31-a6e0-3c9b1d7f2a58/assignee" }\n{ "@timestamp": "2026-09-27T13:20:55.208Z", "@version": "1", "message": "admin_role_changed", "logger_name": "com.fwdford.forwardapi.service.UserService", "thread_name": "http-nio-8080-exec-4", "level": "INFO", "level_value": 20000, "request_id": "2a9f6d4b-7e13-4c85-9b02-e5d8c1a3f746", "service": "forward-api", "event": "admin.user.role_changed", "outcome": "success", "actor_id": "c1a5e9d3-7f2b-4e68-8a04-b6d2f9e1c357", "actor_role": "ADMIN", "target_user_id": "8f14e45f-ceea-467a-9c1e-2b7d3a5c6e90", "from_role": "ATENDENTE", "to_role": "GESTOR", "audit_log_id": 1842 }
```

Catálogo de eventos

Evento	Quando	Campos principais	Nível	Status
service_event_created / service_event_rejected	Registro de evento de serviço	id , vin (a mascarar), dealer_id , reason	INFO / WARN	Implementado
unhandled_error	Exceção não tratada (resposta 500 genérica)	path , stack_trace	ERROR	Implementado
jwt_validator: DISABLED	Inicialização sem validador	nenhum	WARN	Implementado (vira alerta)
auth.login_succeeded / auth.login_failed	Login	user_id , role , reason , src_ip , jti	INFO / WARN	Em implementação (#48, audit_log)
auth.token_rejected	Token ausente, expirado ou inválido	reason , path , src_ip	WARN	Proposto
authz.denied	403 por papel ou por concessionária	user_id , role , required_role , path	WARN	Proposto
ratelimit.rejected	429	bucket , key_hash , limit , path	WARN	Proposto
admin.user.role_changed	Mudança crítica de permissão	actor_id , target_user_id , from_role , to_role	INFO	Proposto (com audit_log)
lgpd.anonymize	Reaper ou pedido do titular	resource_id , reason	audit_log	Implementado (013)
ml.scoring.completed	Fim do lote de scoring	n_scored , psi_vs_train , model_sha256	INFO	Proposto
telemetry.rejected	Mensagem IoT inválida ou replay	device_id , reason , seq	WARN	Proposto

Regras de privacidade dos logs: nunca registrar senha, token, Authorization , CPF, e-mail ou telefone; e-mail só como hash truncado; VIN mascarado; IP de origem mantido por 90 dias por interesse legítimo em segurança (LGPD art. 7, IX, e art. 46); retenção de 90 dias no Loki e audit_log pela política de backup.

3.4 Métricas, SLOs e alertas

As regras estão em [observability/alerts/forwardservice-alerts.yml](#) (7 grupos, 6 regras de gravação e 21 alertas). REQ-02 de 99% significa um orçamento de erro de 1%, ou cerca de **7 h 12 min por mês**; o alerta usa queima de orçamento em duas janelas (14,4 vezes em 1 h e 5 min para acionar plantão, 6 vezes em 6 h e 30 min para ticket), o que evita alarme por oscilação curta.

Domínio	Métrica	SLO ou limite	Alerta	Severidade	Status
API	Latência p95 (Micrometer e borda Fly)	abaixo de 300 ms (REQ-01)	ApiLatencyP95AboveSLO , ApiEdgeLatencyP95AboveSLO	warning	Borda: disponível; Micrometer: planejado

Domínio	Métrica	SLO ou limite	Alerta	Severidade	Status
API	Disponibilidade (probe_success)	pelo menos 99% em 30 dias (REQ-02)	ApiAvailabilityFastBurn , ApiAvailabilitySlowBurn , ApiDown	critical / warning	Planejado
API	Taxa de 5xx	abaixo de 2%	ApiHigh5xxRatio	critical	Planejado
API	401 e 403 por minuto	60 e 20 por minuto	AuthFailuresSpike , ForbiddenSpike	warning	Planejado
API	Falhas de login	20 em 5 min; mais de 10 contas distintas	LoginBruteForce , LoginCredentialStuffing	warning / critical	Planejado
API	Respostas 429	60 por minuto durante 10 min	RateLimitSaturation	warning	Planejado
API	Promoção para ADMIN	qualquer ocorrência	PrivilegedRoleChange	warning	Planejado
Mobile	Sessões sem crash	pelo menos 99,5%	MobileCrashFreeBelowTarget	warning	Planejado
IoT	Atraso de ingestão p95	abaixo de 60 s	TelemetryIngestionLagHigh	warning	Proposto
IoT	Falhas mTLS e ACL negadas	10 por minuto; qualquer ACL negada	MqttAuthFailuresSpike , MqttAclDenied	warning	Proposto
ML	Drift do score (PSI)	até 0,1 estável; acima de 0,25 relevante	MLScoreDriftWarning , MLScoreDriftCritical	info / warning	Planejado
ML	AUC	pelo menos 0,82 (REQ-03); abaixo de 0,78 retreina	MLAucBelowRetrainThreshold	warning	Planejado (atual: 0,9073)
ML	Frescor do scoring	até 26 h	MLScoringJobStale	warning	Planejado
DevSecOps	Crítico aberto há mais de 7 dias	SLA	DevSecOpsCriticalFindingOverdue	warning	Planejado

Configuração planejada da API para expor métricas (depende do PR #48, por isso não foi aplicada):

```
# application.yml (Planejado)
management:
  endpoints.web.exposure.include: health,info,prometheus
  metrics:
    tags.application: forward-api
    distribution.percentiles-histogram.http.server.requests: true
# /actuator/prometheus liberado só para ROLE_SERVICE ou rede interna do Fly (6PN)
```

3.5 Dashboards

O dashboard [observability/dashboards/forwardservice-overview.json](#) (Grafana, schema 39, uid `forwardservice-overview`) tem 6 linhas e 23 painéis: SLO da API, erros e segurança da API (4xx/5xx, 401/403, falhas de login, 429 e logs de segurança do Loki), ML (PSI, AUC, frescor, faixas de risco),

mobile (sessões sem crash, erros de API, crashes por versão), IoT (atraso de ingestão, falhas mTLS e ACL, dispositivos conectados) e DevSecOps (achados por severidade e idade do crítico mais antigo). Para usar: *Dashboards > New > Import*, escolher o Prometheus e o Loki nas variáveis `ds_prom` e `ds_loki`.

Simulação com dados sintéticos. Não foi possível subir Grafana e Prometheus na máquina de build (Docker Desktop sem engine, virtualização desabilitada; tentativa de 10 minutos). Os prints abaixo são de uma página HTML estática gerada a partir **do mesmo JSON** (títulos, consultas e limites) com séries sintéticas ([observability/mock/](#)). Só os painéis marcados "dado real" usam números reais: AUC 0,9073 do `resultados/metrics.json` do `forward-ml` e os totais de achados do pipeline DevSecOps de 27/09/2026.

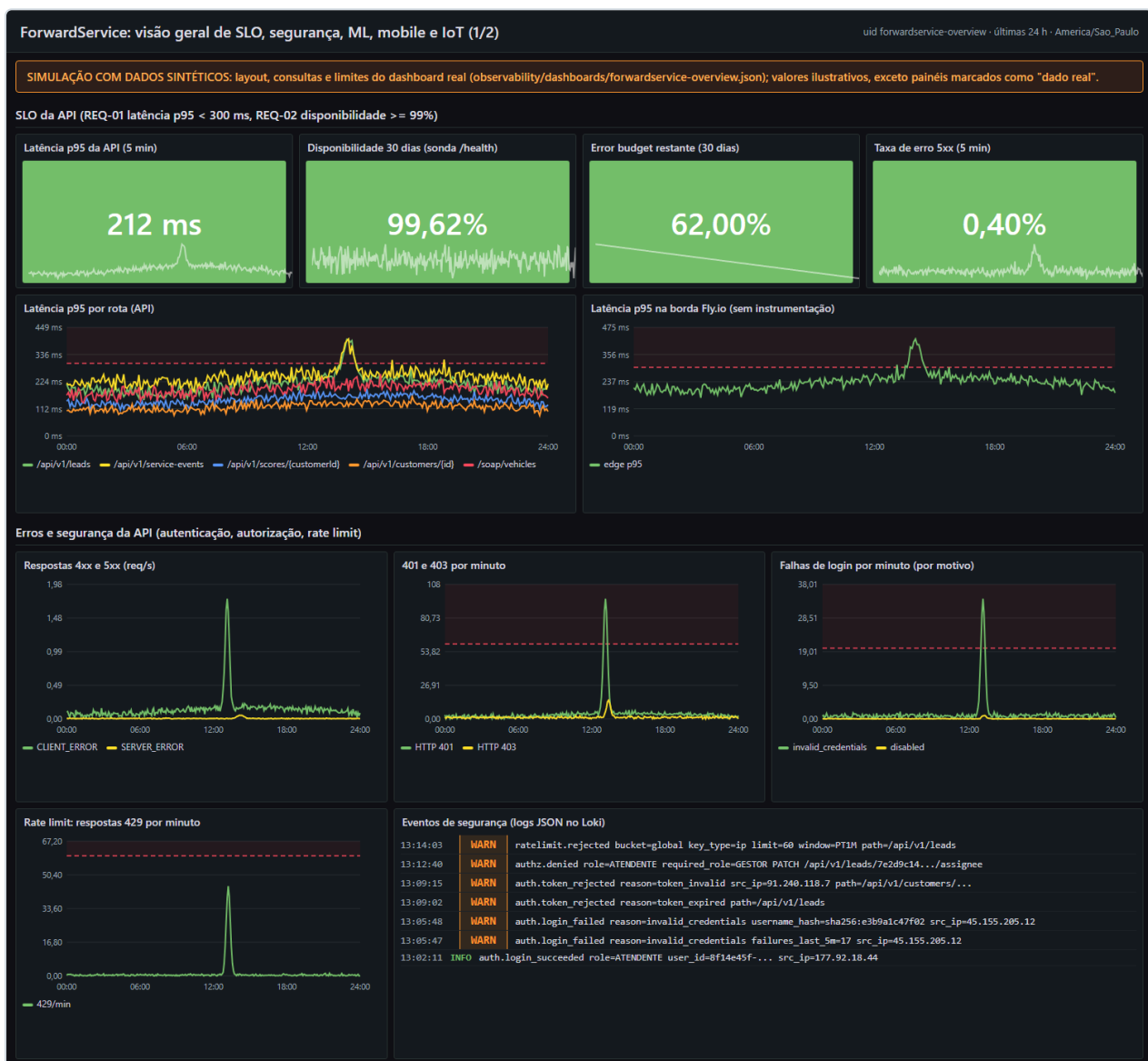


Figura 6. Simulação com dados sintéticos: SLO da API e segurança. O pico às 13h ilustra um ataque de força bruta (401 e falhas de login acima do limite) contido pelo rate limit.

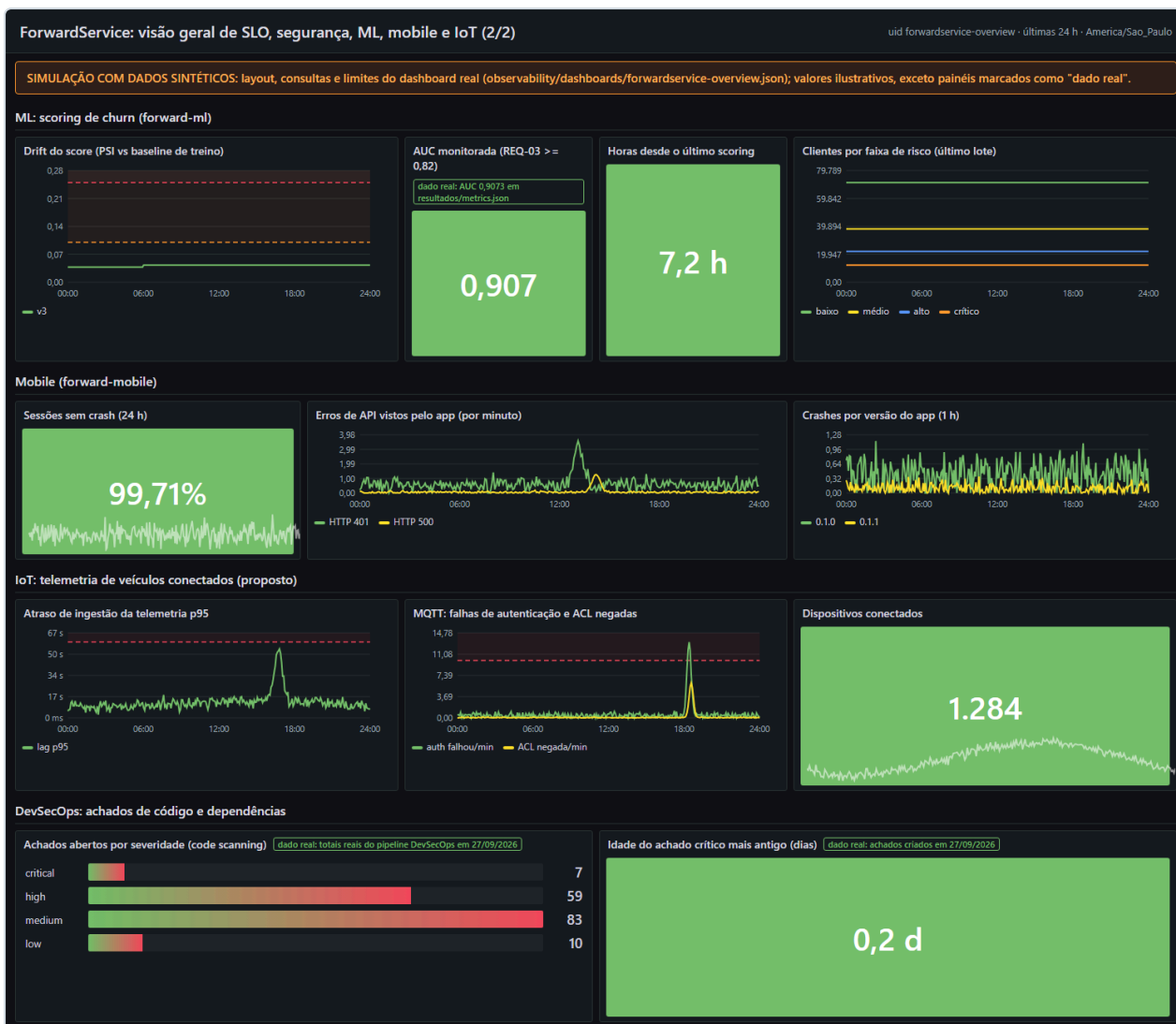
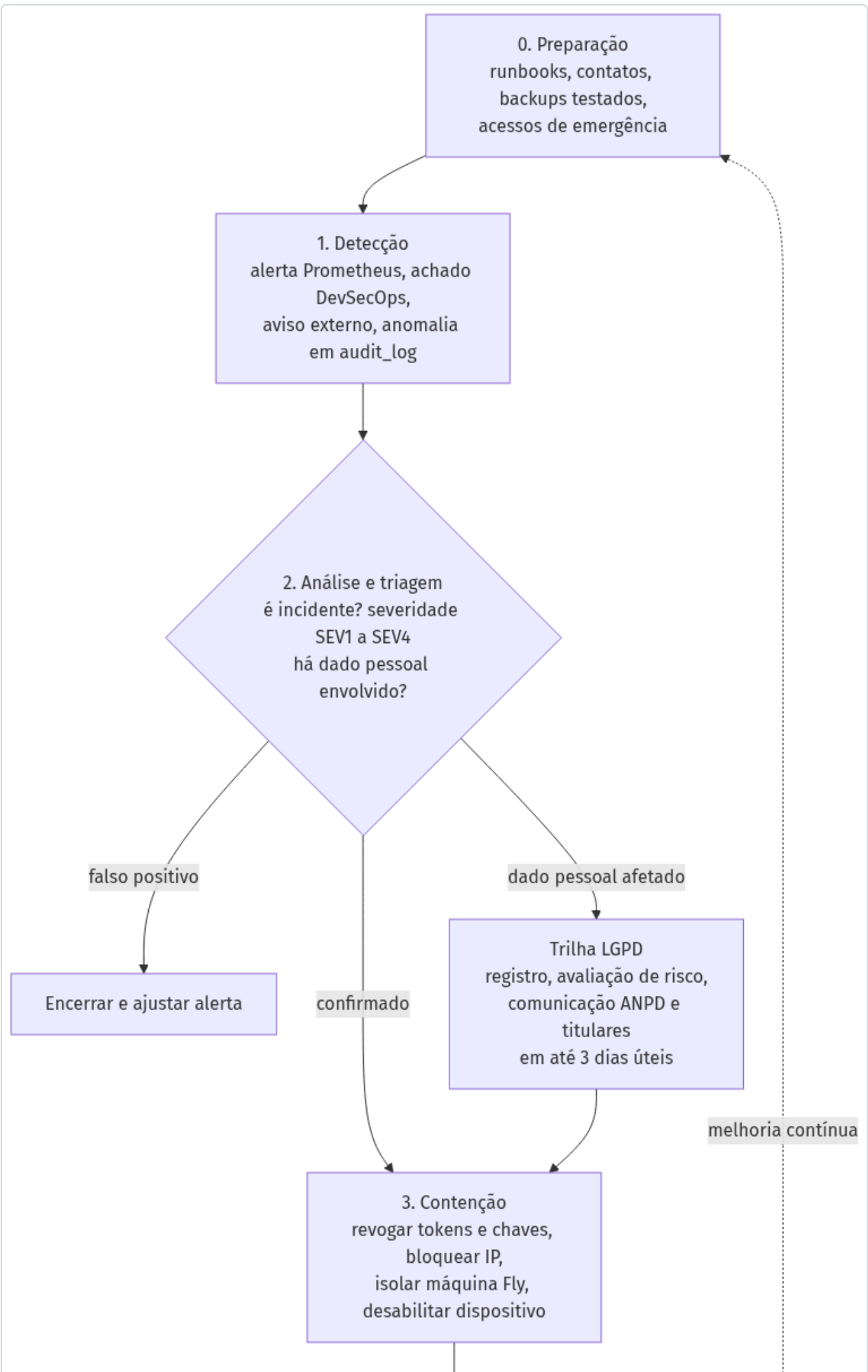


Figura 7. Simulação com dados sintéticos: ML, mobile, IoT (proposto) e DevSecOps (dado real).

3.6 Plano de resposta a incidentes

Baseado no ciclo do NIST SP 800-61 (preparação, detecção e análise, contenção, erradicação, recuperação e atividades pós-incidente), com a trilha de comunicação da LGPD.



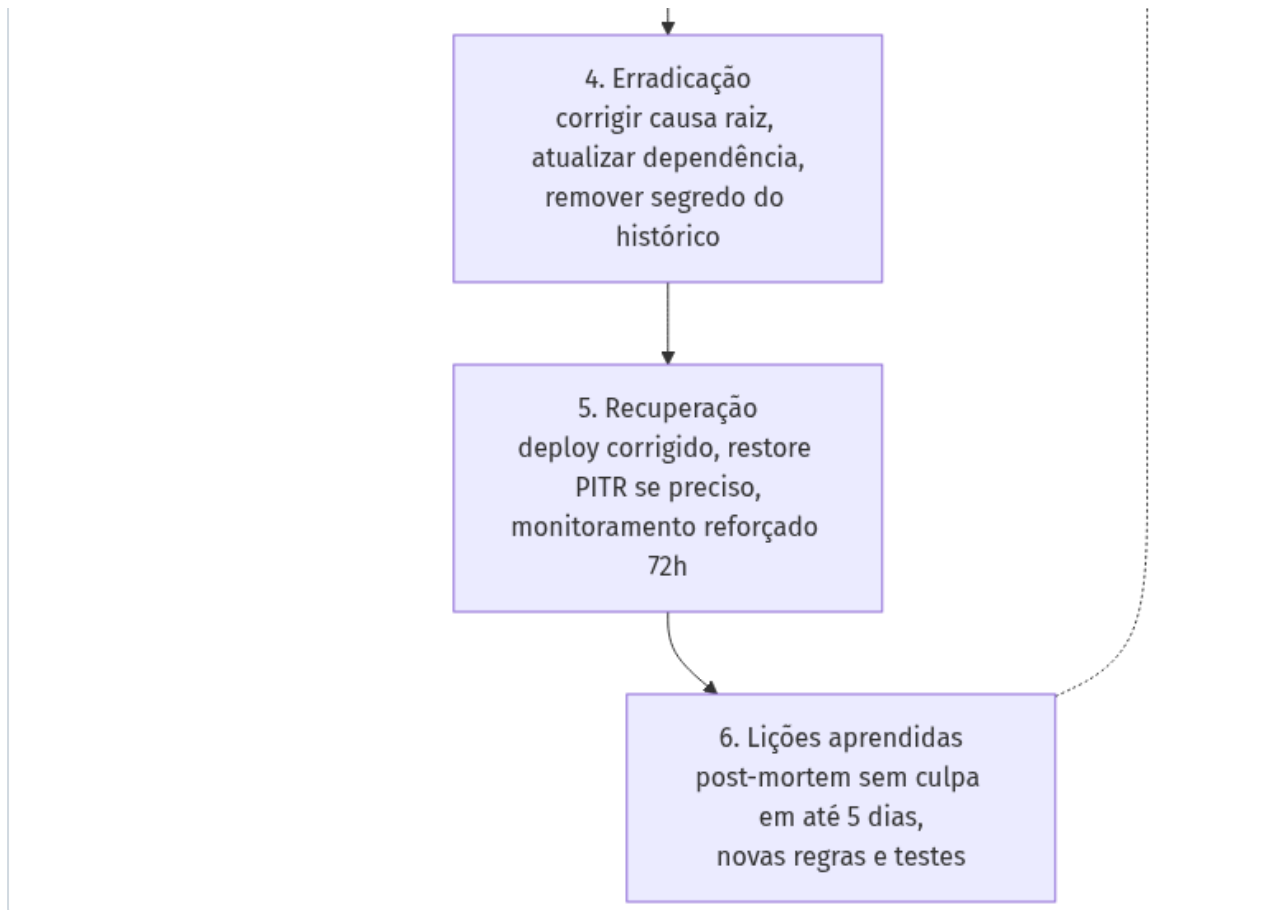


Figura 8. Fluxo de resposta: detecção, análise, contenção, erradicação, recuperação e lições aprendidas, com desvio para a trilha LGPD.

Severidade e tempo de resposta

Severidade	Exemplos no ForwardService	Primeira resposta	Comunicação
SEV1	Vazamento confirmado de dados de clientes; segredo de produção vazado; API fora do ar por mais de 30 min	15 min, 24x7	Líder do grupo e Ford imediatamente; ANPD e titulares em até 3 dias úteis quando houver risco relevante
SEV2	Credential stuffing em andamento; CVE crítica explorável exposta; queima rápida do error budget	1 h	Canal do time; registro no incidente
SEV3	Achado High sem exploração; p95 acima de 300 ms; drift de ML acima de 0,25	1 dia útil	Issue com prazo
SEV4	Achados Medium ou Low; alertas informativos	Próxima sprint	Backlog

Papéis (sugestão inicial, com rodízio no grupo)

Papel	Responsabilidade	Titular sugerido
Coordenador do incidente	Decide severidade, contenção e encerramento	João Victor Franco (owner da organização)
Líder técnico de backend e infraestrutura	Investigação na API, Fly.io e Supabase	Lucca Saraiva Borges
Líder técnico de mobile e ML	Investigação no app, EAS e pipeline de ML	Ruan Melo Vieira
Comunicação, LGPD e registro	Linha do tempo, evidências, comunicação à Ford e à ANPD	Rodrigo César Jimenez

Playbooks

Playbook	Deteção	Análise	Contenção	Erradicação	Recuperação
PB-01 Segredo vazado (JWT_SECRET , INTERNAL_API_KEY , senha do banco)	Gitleaks no pipeline, secret scanning, aviso externo	Onde vazou, desde quando, o que o segredo permite	fly secrets set com valor novo (invalida todos os JWT), revogar a chave do N8N, trocar a senha do banco	Remover do histórico (git filter-repo) e mover para cofre	Deploy, smoke test em /api/v1/me , varrer o audit_log da janela exposta
PB-02 Força bruta ou credential stuffing	LoginBruteForce , LoginCredentialStuffing , AuthFailuresSpike	Eventos auth.login_failed por src_ip e username_hash	Bloquear IPs no Fly, reduzir LOGIN_RATE_LIMIT_MAX , desabilitar contas atacadas	Exigir troca de senha das contas com login suspeito	Monitoramento reforçado por 72 h
PB-03 Vazamento de dados pessoais (LGPD)	ForbiddenSpike , anomalia no audit_log , relato externo	Quais titulares e dados, risco ou dano relevante	Revogar acessos, isolar a máquina, snapshot do banco e dos logs	Corrigir a falha (ex.: BOLA)	Comunicar ANPD e titulares em até 3 dias úteis (art. 48 e Resolução CD/ANPD 15/2024) e registrar o incidente
PB-04 CVE crítica em dependência	Pipeline DevSecOps e Dependabot	Exploração possível no nosso uso? Há correção?	WAF ou regra temporária se explorável	Atualizar a dependência (SLA de 7 dias)	Rodar o pipeline e fechar o alerta
PB-05 Dispositivo IoT comprometido (proposto)	MqttAclDenied , MqttAuthFailuresSpike	Certificado clonado? Padrão de mensagens	Revogar o certificado (CRL) e bloquear o device_id	Reemitir certificado por OTA	Reprocessar a telemetria afetada
PB-06 Drift ou envenenamento do modelo	MLScoreDriftCritical , mudança brusca nas faixas	Comparar a distribuição de entrada com a linha de base	Congelar a geração automática de leads críticos	Retreinar com dados validados e conferir o hash do artefato	Validar AUC igual ou acima de 0,82 antes de liberar
PB-07 Indisponibilidade da API	ApiDown , ApiAvailabilityFastBurn	fly status , último deploy, Supabase	Rollback para a release anterior no Fly	Corrigir a causa	Restore por PITR se houver dado corrompido (BACKUP_RESTORE.md)

Preservação de evidências: exportar logs da janela do incidente antes da rotação, snapshot de audit_log (tabela append-only) e dos artefatos do pipeline, e linha do tempo com request_id . **Pós-incidente:** post-mortem sem culpados em até 5 dias úteis, com causa raiz, ações e novas regras de detecção.

3.7 Evidências da seção

- Dashboard: observability/dashboards/forwardservice-overview.json
- Alertas: observability/alerts/forwardservice-alerts.yml
- Logs: observability/logs/api-logs-formato-atual.jsonl e observability/logs/api-logs-eventos-seguranca.jsonl

- Simulação do dashboard: [observability/mock/dashboard-mock-1-api.html](#) e [observability/mock/dashboard-mock-2-ml-mobile-iot.html](#)

3.8 Limitações

- Métricas `forward_*` e a exposição Prometheus da API ainda não existem; o plano define nomes, limites e consultas para quando forem instrumentadas.
- Os prints do dashboard são simulação; o print real desta entrega é o da execução do pipeline (Figura 3).
- O envio de logs para o Loki não está configurado; hoje os logs ficam no stdout do Fly.io com retenção curta.

4. Compliance, Riscos e Segurança Contínua (peso 2,5)

4.1 Objetivo

Fechar o ciclo com uma revisão final de riscos (STRIDE e DevSecOps), o mapeamento para OWASP ASVS, OWASP Mobile Top 10 2024, OWASP API Security Top 10 2023 e LGPD, e um plano de segurança contínua com rotinas, responsáveis e evidências.

4.2 Revisão final de riscos

Probabilidade (P) e impacto (I) de 1 a 5; nível = $P \times I$ (1 a 6 baixo, 8 a 12 médio, 15 a 25 alto). Riscos da Sprint 1 em [01_THREAT_MODEL.md §6](#) e [03_SECURITY_PLAN.md §3](#).

ID	Risco	STRIDE	Componente	P	I	Nível	Tratamento	Status
RS-01	Força bruta de token e de login sem rate limit	S, D	API	4	4	Alto (16)	Rate limit antes da autenticação e balde de login	Em implementação (#48)
RS-02	Leitura de clientes de outra concessionária (BOLA)	I	API	3	5	Alto (15)	Escopo por concessionária na camada de serviço (o RLS não cobre a API, RS-16)	Em implementação (#48)
RS-03	CVEs críticas no Tomcat e High no Spring e Jackson	T, E	API	3	5	Alto (15)	Atualização com SLA de 7 dias	Planejado
RS-04	CPF em claro no banco	I	Dados	2	5	Médio (10)	pgcrypto ou HMAC	Planejado
RS-05	Segredo commitado	I, S	Todos	2	5	Médio (10)	Gitleaks no histórico (0 achados) e push protection	Mitigado / Planejado
RS-06	Action de terceiro comprometida no CI	T, E	CI/CD	2	5	Médio (10)	Pins por SHA e checksums no pipeline novo	Mitigado no novo pipeline; antigos planejados
RS-07	Shell injection em workflows reutilizáveis	T, E	CI/CD	2	4	Médio (8)	Inputs via env	Planejado
RS-08	API aberta por configuração ausente (fail-open)	E	API	2	5	Médio (10)	Falha na inicialização em produção	Em implementação (#48)
RS-09	Token do app extraído do aparelho	I	Mobile	1	4	Baixo (4)	SecureStore, expiração e logout em 401	Mitigado
RS-10	Toolchain npm vulnerável	T	Mobile (build)	2	3	Baixo (6)	Dependabot e SBOM	Planejado
RS-11	Dispositivo IoT clonado ou falso	S, T	IoT	3	4	Médio (12)	mTLS, ACL, CRL e anti-replay	Proposto
RS-12	Artefato de modelo adulterado (pickle)	T, E	ML	1	5	Baixo (5)	Hash SHA-256 e origem confiável	Planejado

ID	Risco	STRIDE	Componente	P	I	Nível	Tratamento	Status
RS-13	Falta de logs de segurança para investigar incidente	R	API	3	3	Médio (9)	Catálogo de eventos, JSON e <code>audit_log</code>	Parcial
RS-14	Perda de dados do banco	D	Dados	1	5	Baixo (5)	Backup diário, PITR e teste mensal de restore	Mitigado (teste manual)
RS-15	Indisponibilidade acima do SLO	D	API	2	3	Baixo (6)	SLO, burn rate e rollback	Planejado
RS-16	RLS sem efeito sobre a API (falsa defesa em profundidade)	E, I	Dados	2	4	Médio (8)	Papel de banco dedicado com <code>FORCE ROW LEVEL SECURITY</code>	Planejado

Correção de premissa da Sprint 1: o [01_THREAT_MODEL.md](#) trata o RLS como segunda barreira atrás da API; a revisão mostrou que isso só vale para o acesso direto ao Supabase (F-17 e RS-16).

Situação dos riscos residuais da Sprint 1: R1 (RBAC declarativo) em implementação no #48; R2 (cifra de campo) planejado, reforçado por RS-04; R3 (mascaramento de PII em log) planejado (F-07); R4 (auditoria de CRUD sensível) parcial, o #48 grava login no `audit_log`; R5 (rate limit distribuído) inalterado com uma instância; R6 (X-API-Key em tempo constante) em implementação no #48; R7 (WAF) planejado.

4.3 Checklist: OWASP ASVS 4.0.3

Status do checklist (seções 4.3 a 4.6): **Atende** (controle implementado e evidenciado), **Parcial** (parte implementada ou em PR aberto) e **Planejado** (sem implementação). IDs da versão 4.0.3 do ASVS; a migração para a numeração do ASVS 5.0 fica para o próximo ciclo.

Requisito	Controle no projeto	Evidência	Status
V1.1.2 Modelagem de ameaças	STRIDE da Sprint 1 e revisão final	01_THREAT_MODEL.md , seção 4.2	Atende
V2.2.1 Anti-automação contra força bruta	Bucket4j por IP e usuário; balde de login no #48	Seção 2.4 (teste em produção)	Parcial
V2.4.1 Hash de senha adaptativo	BCrypt no login próprio	AuthService (#48)	Parcial
V2.10.4 Segredos fora do código	Fly secrets, <code>.env.example</code> , Gitleaks sem achados no histórico	Runs da seção 1.6	Atende
V3.5.3 Token stateless assinado e à prova de adulteração	Assinatura verificada, allowlist de algoritmo; iss, aud e jti no #48	JwksJwtValidator, JwtService	Parcial
V4.1.1 Controle de acesso em camada confiável	RBAC aplicado no servidor, na camada de serviço (o RLS protege só o acesso direto ao Supabase, F-17)	ScoreService, CustomerService	Atende
V4.1.3 Menor privilégio	Permissões por papel; RLS nega por padrão	Role.java (#48), 010	Parcial
V4.2.1 Proteção contra IDOR/BOLA	Escopo por concessionária	CustomerService (F-06), #48	Parcial
V5.1.3 Validação por allowlist	Regex de UUID, VIN e enum; Bean Validation	Validations.java	Atende

Requisito	Controle no projeto	Evidência	Status
V5.3.4 Consultas parametrizadas	NamedParameterJdbcTemplate	repository/	Atende
V7.1.1 Sem credenciais em log	Nenhum header Authorization ou senha logado	RequestIdFilter, catálogo 3.3	Atende
V7.1.3 Log de eventos de segurança	Login no audit_log (#48); catálogo de eventos	Seção 3.3	Parcial
V7.1.4 Contexto para investigação	@timestamp e request_id em JSON	logback-spring.xml (F-08)	Parcial
V7.4.1 Erro genérico ao cliente	RFC 7807 sem stack trace	GlobalExceptionHandler.java	Atende
V8.2.2 Nada sensível no storage do navegador	Token no SecureStore; build web usa localStorage	session.ts	Parcial
V8.3.4 Dados sensíveis identificados	Inventário de dados pessoais	Seção 4.6	Atende
V8.3.8 Retenção e eliminação automática	Reaper diário e anonimização	013_lgpd_retention_policy.sql	Atende
V9.1.1 TLS para todos os clientes	force_https , HSTS e APK sem cleartext	fly.toml, app.config.js	Atende
V9.2.2 TLS nas conexões de saída	Supabase via pooler com sslmode=require (documentado); dev local sem TLS	.env.example do forward-infra (linha 10)	Parcial
V10.3.2 Integridade de artefatos	Pins por SHA, checksums, SHA256SUMS do APK; imagem sem assinatura	devsecops.yml, android-apk.yml	Parcial
V13.2.5 Content-Type verificado	consumes = application/json no POST	ServiceEventController.java	Atende
V13.3.1 Validação XSD no SOAP	Só VIN validado no endpoint	WebServiceConfig.java (F-16)	Planejado
V14.1.1 Build e deploy seguros e repetíveis	Workflows reutilizáveis e pipeline DevSecOps	Seção 1	Atende
V14.2.1 Componentes atualizados	Trivy, pip-audit e Dependabot; há CVEs abertas	Seção 1.6	Parcial
V14.2.5 SBOM mantido	CycloneDX em todo run	Artefatos devsecops-sbom	Atende
V14.3.3 Sem versão de componente nos headers	server: Fly/... sem versão do Tomcat	Curl da seção 2.4	Atende
V14.4.3 a V14.4.7 Headers de segurança	CSP, nosniff, HSTS, Referrer-Policy, frame-ancestors; ausentes no 401	Seção 2.4 (F-01)	Parcial
V14.5.3 CORS com allowlist estrita	ALLOWED_ORIGINS , sem curinga	CorsConfig.java	Atende

4.4 Checklist: OWASP Mobile Top 10 (2024)

Requisito	Controle no projeto	Evidência	Status
M1 Improper Credential Usage	Nenhuma credencial de serviço no app (a anon key saiu no #98); só o JWT do usuário	app.json, session.ts	Atende
M2 Inadequate Supply Chain Security	Trivy no lockfile, Dependabot, SBOM de 680 componentes; 1 Critical e 36 High no toolchain	Run 36299071189	Parcial

Requisito	Controle no projeto	Evidência	Status
M3 Insecure Authentication/Authorization	Login na API com expiração e logout em 401; autorização no servidor	auth.ts, api.ts, #48	Parcial
M4 Insufficient Input/Output Validation	Validação de formulário no app; servidor valida tudo	validation.ts (F-14)	Parcial
M5 Insecure Communication	HTTPS-only no APK de release e HSTS; sem certificate pinning	app.config.js	Parcial
M6 Inadequate Privacy Controls	Cidade escolhida manualmente (sem GPS), avatar só no aparelho, só permissão de câmera	app.json, profile.ts	Atende
M7 Insufficient Binary Protections	Sem R8/ofuscação e sem chave de assinatura própria documentada	android-apk.yml (F-14)	Planejado
M8 Security Misconfiguration	Permissões mínimas e <code>blockedPermissions</code> ; <code>allowBackup</code> no padrão do Expo	app.json	Parcial
M9 Insecure Data Storage	Token no SecureStore; AsyncStorage só com preferências	session.ts, storage-keys.ts	Atende
M10 Insufficient Cryptography	Cripto delegada ao sistema (Keystore/Keychain) e TLS; nada caseiro	session.ts	Atende

4.5 Checklist: OWASP API Security Top 10 (2023)

Requisito	Controle no projeto	Evidência	Status
API1 Broken Object Level Authorization	Escopo por concessionária na camada de serviço	F-06, F-17, #48	Parcial
API2 Broken Authentication	JWT assinado com exp; login com BCrypt, anti-enumeração e rate limit (#48)	JwtService, AuthService	Parcial
API3 Broken Object Property Level Authorization	DTOs <code>record</code> explícitos, sem mass assignment; Bean Validation	model/, CreateServiceEventRequest	Atende
API4 Unrestricted Resource Consumption	Bucket4j, corpo de 1 MB, <code>limit</code> até 200; 401 sem rate limit	F-01	Parcial
API5 Broken Function Level Authorization	<code>@PreAuthorize</code> por papel (#48); na main a checagem é inline	ScoreService, Role.java	Parcial
API6 Unrestricted Access to Sensitive Business Flows	Rate limit, HMAC para o N8N, transições de status do lead validadas	HmacValidator, lead-status.ts	Parcial
API7 Server Side Request Forgery	Nenhuma URL vinda do usuário é buscada; CVE de SSRF no spring-ws a atualizar	T-02	Parcial
API8 Security Misconfiguration	Headers, CORS, actuator restrito, pipeline laC; CVEs do Tomcat	Seções 2.4 e 2.7	Parcial
API9 Improper Inventory Management	<code>openapi.yaml</code> versionado e espelhado no forward-docs; prefixo <code>/api/v1</code>	api/openapi.yaml	Atende
API10 Unsafe Consumption of APIs	Integrações limitadas a Supabase e N8N; N8N com HMAC	HmacValidator.java	Parcial

4.6 Checklist: LGPD (dados pessoais, telemetria e localização)

Requisito	Controle no projeto	Evidência	Status
Art. 6 Princípios (finalidade, necessidade, segurança)	ML sem PII direta; cidade manual; telemetria mínima proposta	forward-ml, seção 2.6	Atende

Requisito	Controle no projeto	Evidência	Status
Art. 7 Base legal	Consentimento (<code>lgpd_consent_at</code>) e legítimo interesse no pós-venda, a registrar no ROPA	002_create_customers.sql	Parcial
Art. 12 Dados anonimizados fora do escopo	<code>anonymize_customer()</code> remove PII e mantém as FKs	013, linhas 21-57	Atende
Art. 15 e 16 Término e eliminação	Reaper: 30 dias após pedido e 12 meses sem consentimento	013, linhas 66-93	Atende
Art. 18 Direitos do titular	Marca de pedido de exclusão e anonimização; sem canal de autoatendimento	013, linhas 12-13	Parcial
Art. 20 Revisão de decisão automatizada	O score só prioriza o contato e o atendente humano decide; SHAP explica o modelo	forward-ml <code>reports/</code>	Parcial
Art. 37 Registro das operações	<code>audit_log</code> append-only; ROPA formal	009_create_audit_log.sql	Parcial
Art. 38 Relatório de impacto (RIPD)	Modelo a elaborar antes do piloto com dados reais	Seção 4.6	Planejado
Art. 41 Encarregado (DPO)	Não atribuído (piloto acadêmico)	03_SECURITY_PLAN §4	Planejado
Art. 46 Medidas de segurança	TLS, RLS, JWT, rate limit, pipeline DevSecOps, backups	Seções 1 e 2	Atende
Art. 48 Comunicação de incidente	PB-03 com prazo de 3 dias úteis (Resolução CD/ANPD 15/2024)	Seção 3.6	Atende
Art. 49 Segurança desde a concepção	Princípios privacy by default e defense in depth	03_SECURITY_PLAN §1	Atende
Telemetria e localização	Payload sem PII, localização de cerca de 1 km, <code>device_id</code> pseudônimo	iot/telemetry.schema.json	Planejado

Inventário de dados pessoais (base do ROPA e do futuro RIPD)

Dado	Categoria	Onde	Finalidade	Base legal	Retenção	Proteção
Nome, e-mail, telefone, cidade/UF	Pessoal (contato)	<code>customers</code>	Contato de pós-venda	Consentimento ou legítimo interesse	Até pedido de exclusão (30 dias) ou 12 meses sem consentimento	RLS, TLS, anonimização
CPF	Pessoal (identificador)	<code>customers.cpf</code> e <code>cpf_hash</code>	Deduplicação	Execução de contrato	Idem	Hash SHA-256; cifra planejada (F-09)
VIN e histórico de serviço	Pessoal indireto (vinculável ao dono)	<code>vehicles</code> , <code>service_events</code>	Previsão de revisão	Legítimo interesse	Enquanto houver relação	RLS; mascarar em log (F-07)
Score de churn e segmento	Inferência sobre a pessoa	<code>churn_scores</code>	Priorizar o contato	Legítimo interesse (art. 20: revisão humana)	Último lote mais histórico de 12 meses	Só perfis internos (RLS)
Usuário do app (atendente)	Pessoal (funcionário)	<code>app_users</code> (#48)	Autenticação e auditoria	Execução de contrato	Enquanto ativo	BCrypt, <code>audit_log</code>

Dado	Categoria	Onde	Finalidade	Base legal	Retenção	Proteção
Telemetria e localização	Pessoal (comportamento e local)	Proposto	Previsão de manutenção	Consentimento no app Ford	90 dias em bruto, depois agregado	mTLS, localização reduzida
IP e user agent em logs	Pessoal (técnico)	Logs e audit_log	Segurança	Legítimo interesse (art. 7, IX)	90 dias	Acesso restrito

4.7 Resumo do checklist de compliance

Framework	Itens	Atende	Parcial	Planejado
OWASP ASVS 4.0.3	28	15	12	1
OWASP Mobile Top 10 2024	10	4	5	1
OWASP API Security Top 10 2023	10	2	8	0
LGPD	13	6	4	3
Total	61	27	29	5

Os 29 itens parciais concentram-se em autenticação, autorização por objeto e dependências: 15 deles dependem diretamente do merge do PR #48 ou da atualização do Spring Boot e do Tomcat (T-01 e T-02).

4.8 Plano de segurança contínua

Rotina	Frequência	Como	Responsável	Evidência gerada	Escala se
Revisão de dependências	Semanal (segunda) e a cada PR	Dependabot com cooldown de 7 dias; agendamento do DevSecOps (segunda, 03h BRT); triagem no code scanning	Líder técnico de cada repo (rodízio)	PRs do Dependabot mergeados, alertas fechados	Critical aberto há mais de 7 dias
Testes de segurança	A cada PR (SAST, SCA, segredos, IaC); semanal (varredura completa); mensal (DAST ZAP baseline em staging, planejado); semestral (revisão manual)	devsecops.yml , OWASP ZAP	Cyber e QA	URLs dos runs, relatório ZAP	Achado Critical novo
Auditoria de permissões	Mensal	gh api orgs/fwd-ford/members , colaboradores externos e rulesets; acessos no Fly.io e Supabase; <code>SELECT email, role FROM app_users WHERE role = 'ADMIN' ; SELECT * FROM pg_policies</code>	Owner da organização	Checklist registrado em forward-docs	ADMIN sem justificativa

Rotina	Frequência	Como	Responsável	Evidência gerada	Escala se
Backup e recuperação	Diário (automático); mensal (teste de restore); trimestral (simulação de desastre)	Backup do Supabase e PITR; pg_dump ; runbook de BACKUP_RESTORE.md §7 (RPO 24 h, RTO 2 h)	Responsável por infraestrutura	Registro em runbooks/restore-tests/AAAA-MM.md	Restore com falha
Rotação de segredos	Trimestral e em todo incidente	fly secrets set , segredos do GitHub e do N8N	Owner	Registro rotate_secret no audit_log	Suspeita de vazamento
Revisão de logs e alertas	Diária (alertas), semanal (tendências), mensal (ajuste de limites)	Grafana e Alertmanager	Plantão	Notas da revisão	Alerta ignorado duas vezes
Revisão do modelo de ameaças	Trimestral e a cada mudança de arquitetura	STRIDE	Cyber	Documento atualizado	Componente novo (ex.: IoT)
Revisão LGPD	Semestral	ROPA, RIPD, prazos de retenção	Encarregado (a nomear)	Relatório	Novo uso de dado pessoal

SLA de correção por severidade: Critical 7 dias, High 30 dias, Medium 90 dias, Low sem prazo (backlog).

Indicadores (KPIs)

Indicador	Linha de base (27/09/2026)	Meta
Repositórios com pipeline DevSecOps	4 de 4 repositórios de aplicação, mais o .github	100% (incluir forward-web e forward-docs)
Achados Critical abertos	7 na contagem por ferramenta (as 3 CVEs do Tomcat aparecem no fs e na imagem; 1 no mobile)	0
Idade do Critical mais antigo	Menos de 1 dia (primeira varredura)	Até 7 dias
Segredos encontrados no histórico	0	0
Testes de restore com sucesso	Runbook manual existente	1 por mês
Revisão de acessos concluída	Não iniciada	1 por mês

4.9 Limitações e próximos passos

- O status dos itens "Parcial (#48)" deve ser revisto depois do merge do PR #48 e de um novo run do pipeline.
- Dependency graph, secret scanning e push protection dependem de configuração do owner da organização.
- RIPD, ROPA e nomeação do encarregado são pré-requisitos para qualquer piloto com dados reais de clientes Ford.

Anexos

A. Índice de evidências

Tipo	Link
Workflow reutilizável	fwd-ford/.github devsecops.yml
PRs do pipeline	.github#4 , .github#10 , api#47 , mobile#97 , infra#42 , ml#32 , web#3
Runs na <code>main</code>	api , mobile , infra , ml , .github
Iteração do pipeline	falha por HTTP 429 e correção validada
Código de segurança em implementação	forward-api-java#48
Código de segurança mergeado	forward-mobile#98
Achados consolidados	evidencias/devsecops-achados-2026-09-27.json

B. Arquivos desta entrega

Arquivo	Conteúdo
<code>ENTREGA_CYBER_SPRINT3.md</code> , <code>.html</code> , <code>.pdf</code>	Este documento (o HTML e o PDF são gerados a partir do Markdown)
<code>img/</code>	Diagramas (Mermaid renderizado em PNG), prints do dashboard simulado e do run real
<code>diagrams/</code>	Fontes Mermaid dos diagramas
<code>observability/dashboards/forward service-overview.json</code>	Dashboard Grafana
<code>observability/alerts/forwardservice-alerts.yml</code>	Regras de alerta Prometheus
<code>observability/logs/*.jsonl</code>	Exemplos de log estruturado (formato atual e eventos de segurança)
<code>observability/mock/*.html</code>	Simulação estática do dashboard com dados sintéticos
<code>iot/</code>	Desenho proposto: <code>mosquitto.conf</code> , <code>acl</code> , <code>telemetry.schema.json</code>
<code>evidencias/devsecops-achados-2026-09-27.json</code>	Achados por repositório, ferramenta e severidade
<code>tools/</code>	Scripts que regeneram o HTML/PDF (<code>build_html.mjs</code>), o dashboard (<code>gen_dashboard.py</code>) e a simulação (<code>gen_mock.py</code>)

Gerado a partir de ENTREGA_CYBER_SPRINT3.md (forward-docs, academic/cyber/sprint3) em 27/09/2026. Imagens incorporadas; links relativos apontam para a branch main do repositório.